

Full length article

Beyond the automation gap: A survey of continuous audit for IoT security[☆]Obrina Briliyant^{a,b} , Amir Javed^a , Yulia Cherdantseva^a ^a Cardiff University, Cardiff, UK^b Politeknik Siber dan Sandi Negara, Bogor, Indonesia

ARTICLE INFO

Keywords:

Security compliance
Continuous audit
IT audit
Governance
Risk
And compliance
IoT security
Security policy
Security standards

ABSTRACT

Despite decades of research into automated compliance, real-world adoption remains surprisingly low. This implementation gap is particularly significant for auditing Internet of Things (IoT) environments, where the sheer volume of connected devices makes manual security auditing challenging. This adoption gap could cause severe business and governance risks, such as operational disruptions and massive regulatory penalties. By following PRISMA methodology, our review investigates why computer-assisted auditing technologies fail to gain traction in practice. We trace the evolution of compliance automation and reveal a fundamental disconnect: the adoption gap emerges not from technological inadequacy but from interconnected research tensions that neglected the traceability and auditability of the audit itself. Our analysis suggests that closing the adoption gap requires research realignment in a human-centered auditing framework that could be supported by technologies and identifies where each could augment human auditors. Rather than pursuing ever-more sophisticated automation, we argue that effective auditing tools must augment human expertise through responsible human-computer interaction. The review synthesizes diverse approaches across process mining, rule-based matching, machine learning, and language models, consistently finding that technical excellence alone cannot bridge the implementation gap. We conclude by presenting a research roadmap that guides security researchers toward building practically viable solutions that leverage strong technological foundations while addressing the urgent, real-world needs of auditors.

1. Introduction

Organizations are at a critical inflection point in cybersecurity and compliance, accelerated by the rapid rise of intelligent connected devices and the advancement of technologies. The current literature provides evidence of how dramatically emerging tech, such as Artificial Intelligence (AI), blockchain, and edge computing, is reshaping Governance, Risk, and Compliance (GRC), a domain traditionally viewed as necessary but tedious. Compliance has evolved from a point-in-time activity, traditionally carried out annually through burdensome audits, into an ongoing, continuous process. The traditional approach to security and compliance monitoring, is insufficient for the heterogeneous and rapidly evolving IoT landscape, as Dritsas and Trigka (2025) highlight in their work; IoT systems physically cannot run traditional IT compliance agents, resulting in a significant visibility gap for auditors.

This review systematically explores research and existing practices to identify converging trends and significant challenges in automating

security compliance monitoring and verification. Our primary goal is to critically assess the current trajectory of technological compliance approaches and identify actionable directions for research and development. We specifically investigate the obstacles hindering the transition towards continuous security compliance, with the aim of significantly narrowing the existing gap between theoretical research findings and practically-adopted business solutions.

Despite decades of research into automated security compliance tools, real-world adoption rates remain surprisingly low. The disconnect between academic solutions and auditors' needs forms the core motivation for this review.

A 2023 KPMG survey of 240 Chief Ethics and Compliance Officers (CCOs) (KPMG, 2023), also cited by Galis (2023), found that only 18% have deployed process automation in their compliance systems, and 64% report that manual audits consume more than 60% of internal audit budgets.¹ A more recent survey by PWC in 2025 (PricewaterhouseCoopers, 2025) identified only 7% of respondents currently

[☆] Prepared for Computers & Security Journal.^{*} Corresponding author at: Cardiff University, Cardiff, UK.E-mail address: briliyantoc@cardiff.ac.uk (O. Briliyant).¹ These survey findings represent self-reported adoption among compliance officers and audit professionals in North America and Europe. Actual global adoption rates may vary by region, industry maturity, and organization size. Survey respondents may have different definitions of "adoption". These figures should be interpreted as indicative rather than comprehensive.

consider themselves to be leading in compliance, stated “tool complexity and trust issue” as the primary adoption barrier (cited by 71% of surveyed organizations), superseding “cost concerns” (42%) and “skill gaps” (38%).

The adoption gap which reflected in different surveys (PricewaterhouseCoopers, 2025; Galis, 2023; KPMG, 2023) is particularly a critical issue in Internet of Things (IoT) environments, where the dynamic landscape and sheer volume of connected devices makes manual security auditing impractical, if not impossible (Rizvi et al., 2020). Consequently, the nature of IoT heterogeneous device ecosystems also brings complications in the application of standardized compliance solutions (Ito et al., 2021).

To address the scalability challenges of continuous auditing, recent literature has heavily emphasized automated compliance frameworks leveraging formal mathematical verification, blockchain ledgers, and black-box anomaly detection (Alevizos, 2025). Prior surveys and proposed systems typically focus on optimizing algorithmic accuracy or establishing rigid, standardized data schemas to automate control verification. However, these approaches inadvertently create what we term the “automation trap”. By optimizing purely for task replacement and full automation, we argue that they fail to provide the transparent, legally defensible evidence chains required by human auditors. Rather than augmenting the auditor, these automated systems often increase the auditor’s cognitive load and strip them of their professional agency, rendering the tools practically unusable in high-stakes regulatory environments.

Contribution. To address the aforementioned challenges and bridge the implementation gap between academic research and practical auditing, we make the following contributions:

- We provide a comprehensive systematic review of recent studies, mapping the developmental trajectory of automated IoT compliance. We categorize this evolution into three distinct eras: (1) Foundational (rule-based and blockchain architectures), (2) Consolidation (machine learning and edge compliance at scale), and (3) Transformation (Large Language Model (LLM) and multi-agent AI paradigms).
- We introduce a novel conceptualization of the adoption barrier, grounded by tensions we identified in the corpus. Proving that stalled implementation is not a technical failure, but specific barriers that could be addressed by realigning the research trajectory.
- We critically evaluate automated IoT compliance literature through the lens of the organization’s business context and human auditor’s professional mandate. Demonstrating that the current automated compliance technology revolves around device inventory, configuration baseline, and audit data immutability is not enough. Showing that focusing research purely on algorithmic accuracy is not enough. Organizations and auditors need compliance technology that is accurate, applied for heterogeneous multi-layered IoT systems, and legally defensible as compliance evidence.
- We translate our diagnosis of the adoption gap into a prioritized, actionable research roadmap. This roadmap gives researchers specific, measurable evaluation metrics necessary to build computer-assisted audit tools that organizations could potentially adopt.

Organization. Section 2 presents the background of this study, Section 3 discusses related works in the field and how this study differs, and Section 4 discusses the research methodology. Section 5 reviews the evolution of the research landscape and presents the tensions in the research. Section 6 displays an overview of the automation approaches, and Section 7 provides insights on their limitations. Section 8 analyzes the barriers of adoption, while Section 9 highlights the synthesis of tensions and barriers to justify a research roadmap. Finally, Section 10 concludes the paper by providing the takeaways of the study.

2. Background

Before evaluating the technological landscape of IoT security audit, it is important to trace the notion of “continuous auditing” back to its origins in accounting. While computer science frequently conflates “auditing” with basic automated “monitoring” (e.g., anomaly detection), formal auditing is bound by strict professional mandates requiring independent, explainable, and legally defensible evidence. Understanding this historical distinction is critical for the remainder of this paper, as the failure of modern technical research to respect these foundational evidentiary standards is precisely what drives the massive adoption gap between advanced IoT security algorithms and practical enterprise compliance.

2.1. Continuous auditing

The concept of Continuous Auditing (CA) has its roots in financial auditing, with groundwork laid by researchers like Vasarhelyi (1991) in the early 1980s. CA is fundamentally a methodology enabling independent auditors to provide assurance on a subject matter through a series of reports issued either simultaneously with or shortly after the occurrence of the underlying events (CICA/AICPA, 1999). The field has since evolved significantly beyond its financial origins and is now applied to various domains, including security compliance. This evolution has been driven by the potential of integrating automation technologies to make the compliance audit process more frequent, approaching near real-time capabilities.

From the initial groundwork of CA in the early 1990s, two primary perspectives on CA emerged: a purely technical view and a more holistic approach, as examined by Flowerday et al. (2006). This foundational study established the principles of providing timely assurance on subject matter, moving beyond periodic assessments to continuous verification.

There are also research streams focused on improving security audit management or governance-level risk-based audit. Studies such as Al-Karaki et al. (2022), Al-Matari et al. (2018) and Sabillon et al. (2018) proposed various novel frameworks for cybersecurity maturity assessment at an organizational level based on well-known security standards (e.g. ISO 27001). These works primarily focus on the management and governance aspects of security compliance rather than technical automation.

2.2. Automation as an enabler

The advancement of computing power, embedded systems and artificial intelligence has enabled the exploration of automation for various audit tasks, enhancing efficiency and accuracy. This integration marks a significant step towards continuous security compliance audit. Early examples focused on automating specific aspects of security assessments. For instance, studies explored automated security checks using standards like the Security Content Automation Protocol (SCAP), focusing on its components like XCCDF and OVAL (Koschorreck, 2011). Peterside et al. (2016) developed an automated secure configuration checklist using SCAP for auditing network edge devices.

While SCAP offered a promising solution for automated security assessment and compliance checking by using standardized formats and common languages, researchers also pointed out its limitations and the need for broader implementation beyond traditional IT systems (Lubell and Zimmerman, 2017; Koschorreck, 2011). Performing a SCAP compliant audit typically involves authenticating to a system and evaluating the current configurations, a method that avoids intrusive network scanning that can cause system faults (Hahn and Govindarasu, 2011). Despite efforts to broaden its scope like the work by Cheng-Liang Kuo (2015) which provides a SCAP configuration checklist for Android devices, there remains a gap in the availability of such checklists for Internet of Things (IoT) and Industrial Control Systems (ICS).

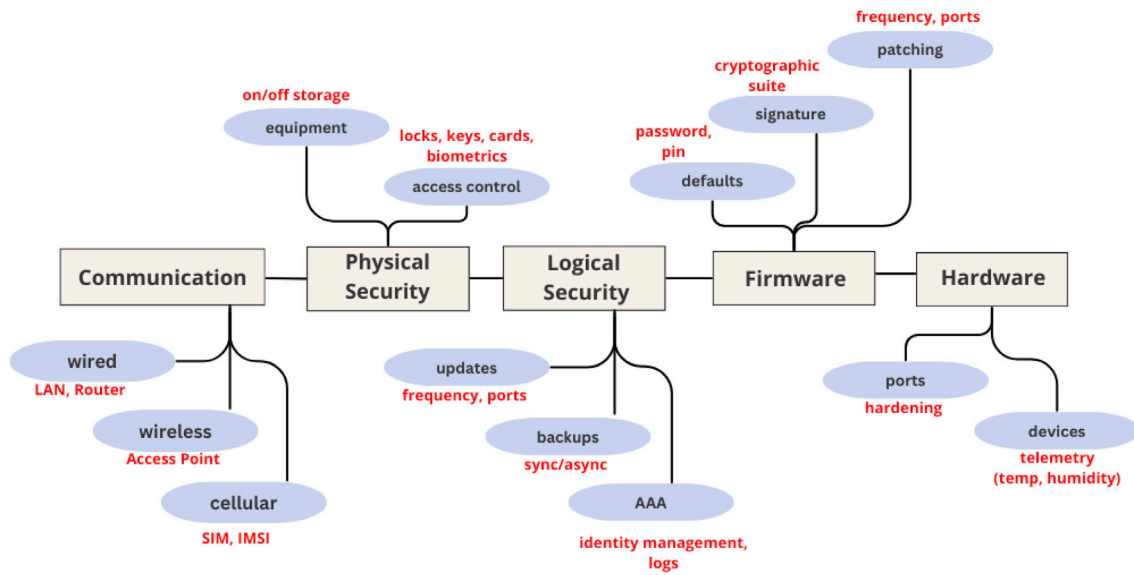


Fig. 1. Auditing framework for IoT devices and networks.

Despite the limitations of SCAP, automated compliance checking methods have been developed for various domains beyond traditional IT. Kellogg et al. (2020) focused on automating compliance checks for source code requirements in agile development. Filepp (2018) introduced a continuous compliance framework for managing security by applying automated reasoning to security regulation management. Automated security assessment tools, like OAuch for OAuth 2.0 security compliance, have been introduced (Philippaerts et al., 2022). Automated verification processes of security policies stated in high-level languages have been demonstrated for scalability (Lorenz et al., 2022). Automated compliance checking has also been explored in the built environment, addressing obstacles and developing roadmaps for adoption (Beach et al., 2020).

Formal verification frameworks have been applied to check compliance with security properties in SCADA systems (Kulik et al., 2020). Standard compliance and continuous verification have been emphasized in Industrial Internet of Things (IIoT), including metric models for compliance verification (Bicaku et al., 2020). Expert systems have been evaluated for cybersecurity standards compliance evaluation, aiming to automate IT architecture assessments against standards like NERC-CIP (Konstantinidis, 2017). Challenges in fully automating the conversion of complex regulatory requirements into computer-processable forms have been addressed using requirement hierarchy and deep learning approaches (Zhang and El-Gohary, 2022, 2012).

2.3. IoT auditing framework

Auditing the Internet of Things requires a structured methodology to handle its multi-layered complexity. Based on the comprehensive architectural framework proposed by Rizvi et al. (2023), IoT security encompasses five foundational pillars: *communication*, *physical security*, *logical security*, *firmware*, and *Hardware*. To effectively conduct security auditing, the audit scope primarily must include four functional domains: firmware, network, telemetry, and hardware (see Fig. 1).

Auditing IoT firmware. The firmware layer serves as the operational brain of the IoT edge device. Auditing this layer requires continuous evaluation of device defaults and the validation of deployed cryptographic suites. Furthermore, compliance assessments must verify the integrity of code signatures to prevent unauthorized modifications and monitor patching frequencies to ensure devices are not operating with deprecated software.

Auditing IoT network. Also mapped to the “Communication” pillar, this domain encompasses the transmission vectors of the IoT ecosystem, including wired (LAN, routers), wireless, and cellular (SIM, IMSI) infrastructures. Auditing the IoT network involves verifying robust network segmentation, ensuring secure communication protocols, and validating that data in transit is protected against interception.

Auditing IoT telemetry. This domain focuses on the raw data generation and communication interfaces. Telemetry involves auditing the continuous streams of sensor data (e.g., temperature, humidity, operational state) to ensure data integrity and verifiable provenance before it is ingested by the wider corporate network.

Auditing IoT physical security. Physical accessibility is a unique attack vector in IoT environments. Auditing physical security involves verifying the implementation of anti-tampering mechanisms, secure boot processes, and the physical hardening of external hardware ports (e.g., locking down exposed USB interfaces). This ensures the hardware cannot be easily manipulated to bypass logical security controls.

2.4. IoT risk-based assessment

To understand the impact of unchecked and unregulated IoT deployment in organization, we map security risks common found in modern businesses directly to the OWASP IoT Top 10 Vulnerabilities (OWASP, 2018), grouping them into four primary IoT cyber-risk vectors: authentication & access compromise, privilege escalation, data breach, and denial of service.

Authentication & access compromise. Authentication failures represent a severe breakdown in logical security. This risk incorporates OWASP vulnerabilities: #1 (Weak, Guessable, or Hardcoded Passwords), #3 (Insecure Ecosystem Interfaces), and #9 (Insecure Default Settings) (OWASP et al., 2021). Non-compliance in this area, such as failing to force password changes on default web interfaces, exposes the entire IoT infrastructure to unauthorized command execution and system takeover.

Privilege escalation & device hijacking. Failures detected during firmware or physical audits pave the way for privilege escalation. This risk vector includes OWASP vulnerabilities: #4 (Lack of Secure Update Mechanism), #5 (Use of Insecure or Outdated Components), and #10 (Lack of Physical Hardening). Attackers exploiting an unpatched component or an exposed physical debug port can bypass initial restrictions, elevating their privileges to manipulate core configurations or inject malicious code into the device.

Table 1
Comparison of our survey with related works.

Survey/Study	Year	Continuous compliance focus	Holistic IoT scope (Cross-Layer)	HCI & Intelligent augmentation
Kumar et al. (2024)	2024	○	•	○
Bakhshi et al. (2024)	2024	○	○	○
Sun et al. (2025)	2025	•	•	○
Dritsas and Trigka (2025)	2025	○	•	○
Our survey	2025	•	•	•

• = Comprehensively covered; ○ = Not covered/partially covered.

Data exposure & privacy breach. With the stringent requirements of regulations like GDPR and HIPAA, data privacy is a primary audit concern. This risk captures OWASP vulnerabilities: #6 (Insufficient Privacy Protection) and #7 (Insecure Data Transfer and Storage). Audits must verify that IoT devices are not storing telemetry data locally in plaintext, nor transmitting sensitive user information over unencrypted network protocols.

Denial of service (DoS) & operational disruption. Resource-constrained IoT devices are notoriously susceptible to DoS attacks. This category encapsulates OWASP vulnerabilities: #2 (Insecure Network Services) and #8 (Lack of Device Management). When audits identify unnecessary open network ports or a lack of centralized asset management, it signifies a high risk of malicious actors overwhelming the edge devices. Such attacks can render critical cyber-physical systems completely unavailable.

3. Related work

This section presents a review of current survey literature on auditing approaches applied to IoT environments, highlighting their contributions and how our survey differs. To the best of our knowledge, this survey is the first to provide a comprehensive review of automated compliance and continuous auditing for IoT devices and networks that explicitly addresses the human-computer interaction (HCI) and cognitive workflow of the auditor.

Recent literature has extensively explored various facets of IoT security, but previous surveys have largely remained siloed within specific technical layers or traditional automation paradigms. For instance, a recent 2024 study by Kumar et al. (2024) evaluated physical and remote IoT security auditing tools, proposing a seven-layer architecture to benchmark security requirements. While valuable for identifying missing features in existing penetration testing and scanning tools, it focuses primarily on pentesting tool capabilities rather than the continuous regulatory compliance process.

Similarly, other studies have adopted a narrow focus on specific IoT components. Bakhshi et al. (2024) provided a detailed review of IoT firmware vulnerabilities and firmware-specific auditing techniques. While this deeply addresses the “Firmware” pillar of IoT security, it does not account for the cross-layer correlation (network, physical, and logical) required for holistic enterprise compliance.

Broader surveys, such as the 2025 study by Sun et al. (2025) have investigated privacy and security protection measures, summarizing firmware defect detection methods (e.g., fuzzy testing, static analysis) and the alignment of enterprise practices with EU privacy laws. Dritsas and Trigka (2025) also surveyed general cybersecurity advancements in IoT. However, these works focus on automation as a mechanism for algorithmic defect detection rather than addressing where current automation effort fail to provide legally defensible evidence for human auditors. Until research addresses this explainability deficit, human auditors cannot justify these automated findings to stakeholders and regulators, rendering the technology practically useless in enterprise environments.

To the best of our knowledge this is the first study to bridge this critical gap. Rather than merely cataloging IoT vulnerabilities or evaluating the mathematical efficiency of anomaly detection algorithms,

we evaluate the literature through the lens of continuous compliance and intelligent augmentation. Table 1 compares this survey with prior studies, emphasizing the main contributions of our current work.

4. Methodology

To ensure a rigorous, transparent, and reproducible process, this review strictly adheres to the Preferred Reporting Items for Systematic reviews and Meta-Analyses (PRISMA) 2020 guidelines (Page et al., 2021). Utilizing PRISMA is particularly significant for this kind of interdisciplinary study, as its standardized framework allows us to objectively map highly fragmented literature, spanning algorithmic IoT security, security automation, and risk compliance governance, and systematically synthesize the thematic shift of the literature.

4.1. Search strategy

This literature study was conducted between October and November 2025 across four major electronic databases and one preprint register: IEEE Xplore, ACM Digital Library, Scopus, Web of Science and ArXiv. To ensure a comprehensive yet highly targeted retrieval of relevant literature, we formulated search queries combining three distinct concept blocks. Logical operators “AND” and “OR” were utilized to enforce the intersection of governance, methodology, and technical domain. The core search string was defined as follows:

1. *Audit concepts (Title)*: [‘security compliance’ OR ‘security audit’]
2. *Automation approaches (Abstract)*: [‘continuous audit’ OR ‘automated compliance’ OR ‘automation’]
3. *IoT domain (all fields)*: [‘internet of things’ OR ‘iot’]

The decision to strictly limit the search to these specific keywords and apply distinct metadata field constraints (title vs. abstract) was driven by the need to filter out massive volumes of tangentially relevant cybersecurity noise. We intentionally excluded generic terms like “cybersecurity” or “threat detection” because our focus is fundamentally on the *governance, verification, and compliance* workflow. Papers focusing solely on raw cryptographic algorithms or physical layer hardware design, while related to IoT security, do not address the continuous auditing and regulatory alignment problem.

Initial exploratory searches using “security audit” anywhere in the text retrieved an unwieldy number of results (tens of thousands), as many technical papers mention auditing purely as a tangential “future work” concept. Restricting this to the *Title* guarantees that the core contribution of the selected study is fundamentally rooted in auditing or compliance.

The solution to the IoT adoption gap relies on automated mechanisms (Flowerday et al., 2006). Requiring automation keywords in the *Abstract* ensures that the proposed framework actively operationalizes continuous methodologies rather than merely proposing theoretical manual checklists.

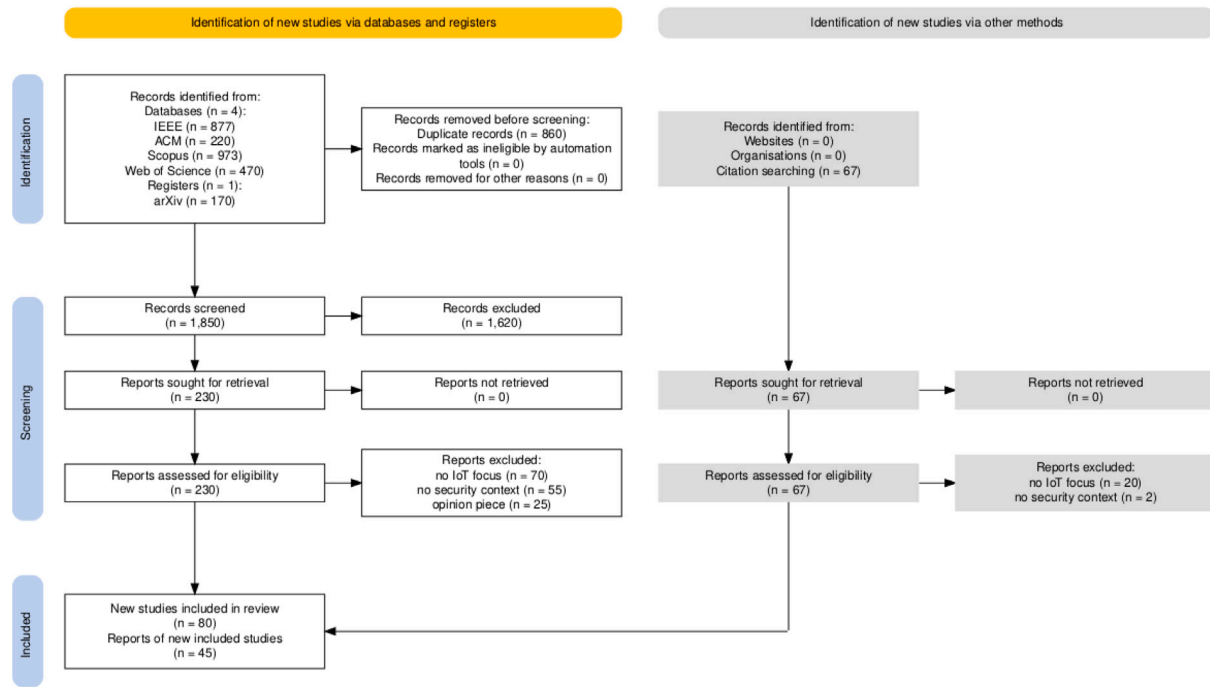


Fig. 2. PRISMA flow diagram showing the screening process.

4.1.1. Screening process

The selection strategy employed specific inclusion and exclusion criteria, followed by a quality assessment to ensure only highly relevant, peer-reviewed studies were synthesized. Elimination was conducted iteratively. First, duplicate records across databases were removed. Next, papers were excluded based on a rapid review of the title, keywords, and abstract. Those that passed this initial phase underwent full-text assessment against our specific criteria.

Inclusion and exclusion criteria: Any paper fulfilling one or more of the following exclusion criteria was immediately removed:

- Not written in English;
- Lacked a full peer-reviewed version (e.g., extended abstracts, posters, or slide decks);
- Focused on algorithmic anomaly detection (e.g., basic ML-IDS) without any mapping to compliance, evidence generation, or auditing workflows;
- Focused on traditional enterprise IT networks rather than resource-constrained or heterogeneous IoT/IIoT ecosystems;
- Proposed manual, point-in-time auditing frameworks lacking an automated or continuous component.

Conversely, papers were included if they met the following criteria: (i) explicitly focused on IoT, IIoT, or Medical IoT ecosystems; (ii) proposed or evaluated an automated mechanism (e.g., rule-based, ML, federated learning, or LLM) to facilitate continuous security compliance or auditing; and (iii) addressed the generation or verification of audit evidence.

The corpus search yielded 2710 records across all databases. After removing duplicates using Zotero's automatic deduplication feature, 1850 unique records underwent title and abstract screening. This process resulted in the exclusion of 1620 studies that did not address IoT audit or compliance automation. The remaining 230 studies underwent full-text assessment using predefined inclusion and exclusion criteria. This screening resulted 80 studies meeting all inclusion criteria.

4.1.2. Citation search

PRISMA guideline also allow complementary source of corpus, including citation search. This is beneficial to our case, because the

fragmented terminology and nascent nature of automated IoT compliance auditing, a significant portion of the final inclusion was identified through backward and forward citation searching. This dual-track approach, and the inclusion of preprint register such as ArXiv ensured that relevant frameworks using non-standardized nomenclature were captured, providing a more comprehensive overview of the automation landscape.

Backward citation searching was performed on all 80 studies, identifying 19 additional relevant papers. Forward citation searching using Scopus "Cited by" feature was performed on the 10 most highly-cited included studies, identifying 48 additional papers. All 67 papers from citation searching underwent full-text assessment using the same predefined criteria, resulting in 45 additional studies that met inclusion criteria. The final corpus includes **125 studies** selected for data extraction and qualitative synthesis.

Fig. 2 illustrates the complete PRISMA 2020 flow diagram showing the study selection process, reasons for exclusion, and identification of studies through alternative methods.

4.2. Risk of bias assessment

As part of PRISMA 2020 compliance, a standardized data extraction form was developed and applied consistently across all 125 included studies. The following data elements were systematically extracted: (a) Bibliographic information: publication year, venue (conference/journal), authors, citation count; (b) Methodological characteristics: study type (empirical/theoretical/conceptual/review), validation approach, sample size; (c) Technical specifications: primary technology category, IoT layer addressed (device/edge/network/cloud), scope (single device to multi-organizational); (d) Compliance dimensions: security standards addressed, automation scope, compliance domain (healthcare/IIoT/ consumer/enterprise); (e) Performance metrics: reported accuracy, precision, recall, F1-score, latency, scalability evidence; and (f) Domain specificity: target IoT environment, device types evaluated, deployment context.

We adapted PRISMA *risk-of-bias* guidance (Page et al., 2021) across six key dimensions. The framework evaluates potential biases that may affect the reliability and generalizability of study findings.

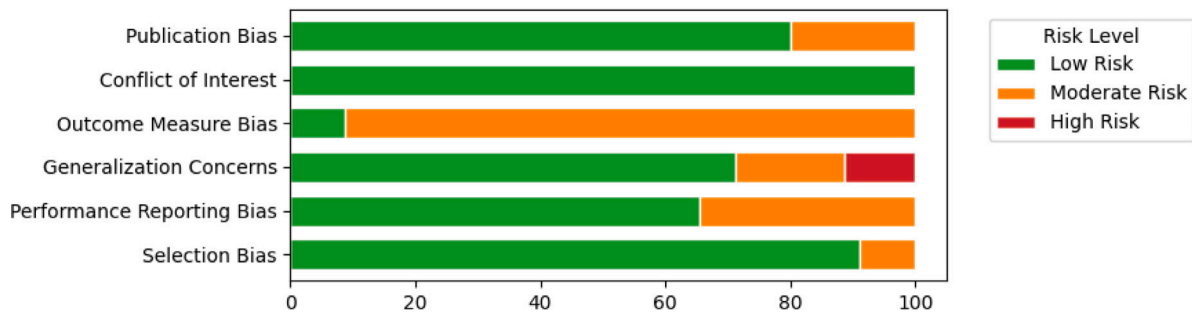


Fig. 3. Risk of bias assessment.

Table 2

Technology approaches by research stream (2017–2025).

Period	Primary approach	Papers (n)	Maturity level	Characteristic shift
2017–now	Rule-based, formal method, ontology-based systems, blockchain	15	Foundation	Static rule-based checking; immutability focus
2021–now	Machine learning, deep learning, federated learning, edge computing	68	Consolidation	Dynamic threat detection; privacy-preserving training
2024–now	Large language models, hybrid systems, RAG, multi-agent AI	42	Transformation	Natural language interpretation; semantic reasoning

Total: 125 papers

1. **Selection Bias:** Most papers provide clear inclusion criteria and adequate samples. However, approximately 8.8% of the reviewed papers represent early-stage conference proceedings with limited validation scope, introducing moderate selection bias.
2. **Performance Reporting Bias:** Approximately 34.4% of the studies exhibited inconsistent metrics reporting, with some emphasizing accuracy while others prioritized speed or scalability. Almost 63% of the studies demonstrated clear, standardized reporting of performance metrics.
3. **Generalization Bias:** This is the biggest concern we detected in the reviewed papers. Most of the papers (over 70%) “claim” that their approach is generalizable, stated in the abstract and/or introduction. But, after further investigation, only 3.2% of the papers **actually demonstrate** true cross-domain applicability through testing. This risk of bias highlights the gap between experimental studies and the real-world application of automated compliance in the IoT context.
4. **Outcome Measure Bias:** Most papers (91.4%) prioritize accuracy metrics, with only 8% explicitly addressing explainability dimensions. This creates potential bias toward accuracy-focused approaches.
5. **Conflict of Interest:** All papers demonstrated clear disclosure and minimal apparent conflicts of interest, with research funding transparently documented.
6. **Publication Bias:** The rapid growth in LLM-based papers may indicate publication bias toward novel technologies, potentially underrepresenting mature but less trendy approaches.

Studies were rated as presenting *Low Risk*, *Moderate Risk*, or *High Risk* for each dimension. Detailed risk-of-bias assessment results are presented in Fig. 3.

4.3. Corpus characterization

Next, we conducted quantitative characterization of the 125 included studies to establish the landscape of research activity, technological evolution, and domain distribution.

Table 3

Domain distribution of included studies.

IoT domain	Studies (n)	Percentage
Industrial IoT (IIoT)	51	40.8%
Medical IoT	30	24.0%
Consumer IoT (smart home)	23	18.4%
Enterprise IoT	15	12.0%
General IoT	6	4.8%
Total	125	100%

Table 4

Methodological profile of included studies.

Study type	Count	%	Avg. Citations
Empirical	79	63.2%	12.4
Conceptual framework	25	20.0%	3.2
Survey/Review	15	12.0%	18.7
Methodological	6	4.8%	2.1
Total	125	100%	–

Publication and technological evolution. Although the corpus search covered 2010–2025, analysis of the full-text screening results revealed that substantive automation research in IoT security compliance did not emerge as a distinct research area until 2017.

Table 2 presents the emerging of technology approaches across three distinct Streams.

The rapid increase in papers from 2024–2025 (33.6% of corpus) reflects accelerating interest in AI-driven compliance automation, particularly following the maturation of large language models suitable for technical analysis.

Domain distribution. The 125 included studies addressed the following IoT environments: Industrial IoT represents the most studied domain, reflecting both regulatory pressures (IEC 62443, NIST Manufacturing Profile) and the critical safety implications of compromised industrial systems. Healthcare IoT constitutes the second-largest category, driven by stringent regulatory requirements (HIPAA, FDA guidance) and high-consequence risks associated with medical device failures (see Table 3).

Methodological profile. The included studies employed diverse research methodologies, as presented in Table 4: Empirical studies constitute

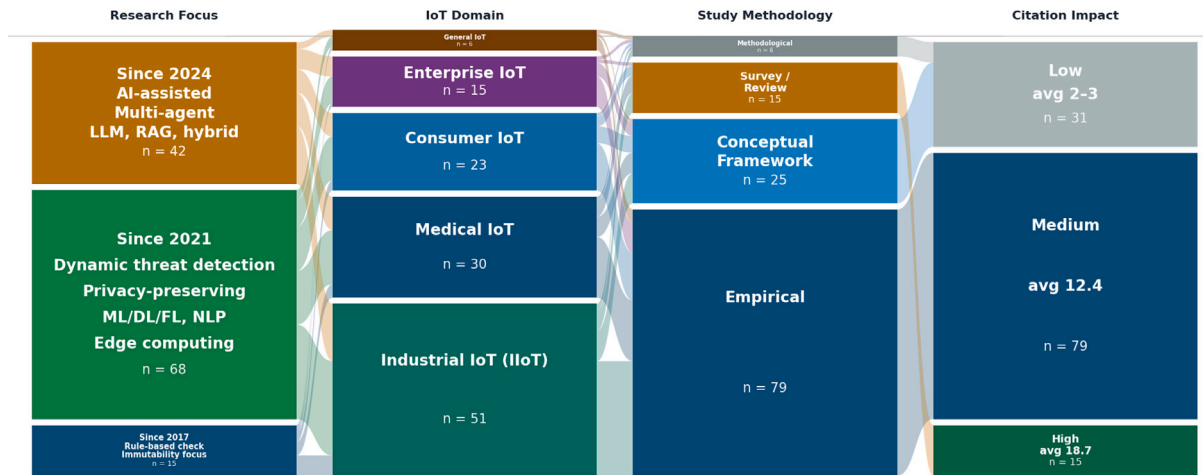


Fig. 4. Literature map of IoT continuous auditing (CA) research.

the majority of the corpus, indicating a practical orientation within the research community. However, median citation counts for systematic reviews (18.7) exceed those of methodological papers (2.1), suggesting that synthesizing research findings receives greater community recognition than tool development.

To visualize the corpus characteristics, Fig. 4 presents literature map of IoT CA research illustrating the flow of the included studies across four analytical dimensions: research Stream, IoT domain, study methodology, and citation impact. The map reveals that “dynamic threat detection” and “privacy-preserving learning” dominates the corpus, contributing 54.4% ($n = 68$) of all studies, with flows distributed proportionally across all five IoT domains and converging predominantly on empirical methodologies. Industrial IoT (IIoT) constitutes the largest domain segment, reflecting sustained research activity across all three temporal Streams. The “AI-assisted” and “semantic reasoning” research, though representing only two years of output, already contributes 33.6% ($n = 42$) of studies, a trajectory consistent with accelerating adoption of large language models and multi-agent AI frameworks in compliance automation research.

5. Evolution of automated compliance in IoT security

In the search for automated compliance towards continuous auditing of the IoT, the research landscape has undergone three milestones, as shown in Table 5. Each is an evolutionary yet interdependent research stream. Our findings suggest that rather than representing discrete paradigm shifts, the literature reflects three cumulative and interdependent research trajectories.

5.1. Stream 1 (2017): Foundational (early automation)

Early work demonstrated technical feasibility of continuous auditing through: node-agent rule-based checking (Waltermire and Fitzgerald-McKay, 2018), process mining for compliance check (MacAk et al., 2020; Jans and Hosseinpour, 2019), formal methods for IoT system verification (Bicaku et al., 2020; Majumdar, 2020), blockchain for audit trails (Barati et al., 2020), and initial ontology-based compliance frameworks (Bella et al., 2023). Typically, in this era, the foundational question that the researcher tries to answer is: *Is automated auditing of IoT technically possible?*

Answer: Yes. Demonstrated through proof-of-concept implementations achieving 95%+ accuracy in controlled environments.

Tension 1: Technical success did not translate to practical adoption (based on survey in Section 1), suggesting technical capability alone is insufficient.

5.2. Stream 2 (2021): Consolidation (scaling automation)

Accelerated research explored scaling automated compliance techniques through machine learning for threat detection (Vutukuru, 2023; Alattas et al., 2022), NLP and knowledge graphs for compliance requirement representation (Anselmi et al., 2023; Echenim and Joshi, 2023), and initial organizational frameworks for integrating continuous audit with governance (Gokhan et al., 2024). The research question shifted:

How can continuous auditing be operationalized at scale across heterogeneous IoT?

Answer: Partial. Multiple approaches demonstrated: ML achieving 95%–99% accuracy (Alattas et al., 2022; Hamdani et al., 2021), federated learning enabling privacy-preserving training (Astillo et al., 2022), edge computing enabling real-time response (Wang et al., 2021), NLP shows high accuracy on semantic analysis (Abu-Tair et al., 2024; Hashmat et al., 2022). However, real-world deployments remained limited or siloed (Section 1).

Tension 2: Research acceleration (increased technical papers) without corresponding increase in real-world validation. Simulation results do not predict field performance.

Tension 3: This Stream saw discovery of the scope-evidence gap: 89% of papers claimed broad IoT applicability while only 3.2% demonstrated it. Claims exceeded evidence by 28:1 ratio.

5.3. Stream 3 (2024): Transformation (contextual automation)

Large Language Models (LLMs), Retrieval Augmented Generation (RAG), and multi-agent systems entered compliance automation. The newest research question the paper ask become: *Can AI interpret complex regulatory requirements and conduct compliance reasoning?*

Answer: Possibly, but unvalidated. LLMs (Hildebrandt et al., 2024; Ghosh et al., 2024) and RAG pipeline (Ju, 2024) reported 85%–95% accuracy on requirement extraction, but only 34% of papers addressed explainability (Jüttner et al., 2023; Deldari et al., 2024), 14% addressed fairness (Asaad et al., 2025), and 5.7% conducted user studies with actual auditors (Foale et al., 2025).

Tension 4: Fastest research growth (33.6% of corpus in 2 years) coupled with the least rigorous evaluation. Newer papers optimize for speed over validation (Ghosh et al., 2024; Hildebrandt et al., 2024).

Each Stream added technical sophistication but did not address why Stream 1 innovations failed to achieve practical adoption (Section 1, 18% adoption after 15 years). Later Streams implicitly assumed earlier technical barriers were the problem.

Table 5
Evolution of automated compliance in IoT security.

Dimension	Stream 1 (2017–now)	Stream 2 (2021–now)	Stream 3 (2024–now)
Primary question	Can compliance audit be automated?	How to integrate automation organizationally?	How to augment auditors with AI?
Dominant technologies	Ontologies, SCAP, Blockchain (foundational), process mining, formal method	ML/DL, NLP, Federated Learning, Edge Computing	LLMs, RAG, Multi-Agent AI
Research focus	Technical feasibility; accuracy metrics	Framework design; governance alignment	Explainability; human-AI interaction
Papers in corpus	15 (12%)	68 (54%)	42 (34%)
Typical validation	Lab/simulator; small n	Multi-tool comparison; limited field studies	Production pilots; case studies
Key limitation	Narrow scope; single domain	Scalability; heterogeneity handling	Generalization; auditor acceptance
Leading application	SCAP/standard-based checking	ML-based threat detection	LLM regulatory interpretation
Organizational readiness	Low (tools immature)	Moderate (frameworks exist, but not exactly compliance check)	Emerging (pilots ongoing)

6. Continuous auditing of IoT devices and networks

In this section, we begin by introducing auditing for IoT and highlighting the differences between IoT audit and IT audit. We then provide an overview of the automation approaches. We categorize this section by: core components of an IoT audit, what are the leading security standards for IoT security, the key insights from automation approaches, and implementation considerations.

6.1. Core framework components

Effective IoT security compliance audit frameworks consistently emphasize a set of core components. These frameworks typically establish specific audit areas and assessment modules, which often include structured compliance checklists mapped to recognized standards such as NIST, ETSI, and IEC (Salva and Blot, 2021). Integral to this is the systematic evaluation of threats and risks pertinent to particular device types and deployment contexts (Matheu-García et al., 2019). Furthermore, these frameworks incorporate certification schemes to formally demonstrate compliance and necessitate post-certification verification to continuously monitor for any deviations from compliance over time (Khurshid and Raza, 2023; Cirne et al., 2022).

Proposed frameworks frequently detail various automation mechanisms designed to enhance the efficiency and accuracy of compliance audits. These mechanisms range from the deployment of smart contracts for deterministic compliance checking (Alromaih et al., 2022). Knowledge graphs are also utilized for semantic representation of requirements, facilitating automated tracing (Tauqeer et al., 2022). Additionally, blockchain systems play a role in providing immutable records of compliance events and audit trails (Islam et al., 2022).

Many academic papers delineate the mapping of technical controls to regulatory requirements. Examples of such controls include Trusted Execution Environments (TEE), blockchain technology, and various cryptographic mechanisms (Wang et al., 2022). This regulatory alignment involves correlating these technical measures with major regulations like GDPR, HIPAA, and the EU Cybersecurity Act. It is recognized that different operational contexts — such as healthcare, industrial, or consumer settings — require distinct emphasis on specific controls (Cejas et al., 2023).

6.2. Review of major IoT security standards

Mandatory regulations, standards and policies are what differentiate auditing with pentesting, vulnerability assessment or other security assessments. In some region, the development of these regulations and standards is already well advanced, such as across European countries, but a lot other region is still nascent. However, many countries now

adopt international standard as the backbone of their own local regulations. To identify unique challenges in deriving actionable security rules, we review several major IoT security standards (as summarized in Table 6).

- NIST IR 8228 (Boeckl et al., 2019). It is an internal report published by the National Institute of Standards and Technology (NIST), a federal agency of the US government. The goal of this report is to assist users in better understanding and managing the cybersecurity and privacy risks associated with individual IoT devices across their life cycles. Particularly, outlines three high-level risk mitigation goals for the security of IoT devices, and each risk mitigation goal is further divided into several risk mitigation areas. NIST IR 8228 has listed 25 requirements along with 49 challenges to achieve those requirements and their mapping with the NIST SP 800-53r5 (NIST, 2020) for mitigating security and privacy risks in IoT systems.
- ETSI EN 303 645 - V2.1.1 (ETSI, 2020). The European Telecommunications Standards Institute European Standard 303 645 (ETSI EN 303 645) establishes a security baseline while covering all consumer IoT devices. The target audience of this guideline are IoT manufacturers and IoT users. This document has 67 provisions with examples divided into 13 high-level recommendations and refers to multiple external documents for further technical details.
- OWASP ISVS (OWASP et al., 2021). OWASP has released IoT Security Verification Standard (ISVS) as a community effort to establish a framework of security requirements for Internet of Things (IoT) applications. The requirements provided by the ISVS can be used at the design, development, and testing of IoT applications. IoT applications are often composed of many interconnected applications that together form a complex ecosystem.

6.3. Proposed automation approach

Table 7 surveys the studies with detailed automation approaches, documenting the diversity of automation strategies and regulatory integration.

Upon analyzing these studies, several key insights emerged regarding automation. The most prevalent approaches identified were smart contracts (Mohsin et al., 2016; Tauqeer et al., 2022) and automated verification (Seul and Varol, 2023; Lorenz et al., 2022; Salva and Blot, 2025), each appearing in 2–3 papers, whereas other methods such as expert systems (Ghanem et al., 2023) and model checking (Cheng et al., 2021) were less frequently mentioned. Moreover, the specification of technical control details, encompassing aspects like rule-based (Mohsin et al., 2017; Hashmat et al., 2022), certificate-based (Lorenz et al., 2022), or ML-based (Bagaa et al., 2020), was found in only 10 of the 40 studies (25%), suggesting that most frameworks were described at a higher, more abstract level.

Table 6
Summary of major IoT security standards.

Security standard	Purpose	Targeted to	Scope	Pages
NIST IR 8228 (Boeckl et al., 2019)	Security and privacy risk management	Users	All kinds of IoT Devices	44
ENISA (for Network and Security, 2017)	Recommendation for baseline security	Users and manufacturers	All kinds of IoT Devices	103
ETSI EN 303 645 (ETSI, 2020)	Consumer IoT Security	Manufacturers	All kinds of IoT Devices	34
OWASP ISVS (OWASP et al., 2021)	Secure development and usage	Manufacturers, developers and users	All kinds of IoT Devices	29
UK Govt (for Digital Culture Media & Sport, 2018)	Improve the security of consumer IoT	Manufacturers, developers and service providers	Smart homes and smart wearables	24

6.3.1. Blockchain in compliance audit

Blockchain has been proposed for two distinct compliance audit functions: for audit trail integrity, maintain immutable record of compliance assessment events (device checked, result recorded, auditor verified, time stamped) to prevent post-facto audit trail modification.

Regulatory requirements (HIPAA, GDPR, ISO 19011 or 15408-2) mandate auditor independence and evidence integrity. Blockchain provides cryptographic proof that audit events were recorded in sequence without modification, providing immutability. Cha et al. (2023), Upadhyaya and Thangaraju (2022) and Mohsin et al. (2016) emphasize blockchain for immutability. Smart contracts encode compliance verification logic into a results recorded on blockchain ledger with timestamp and auditor signature, providing non-repudiation. Zhang et al. (2024) and Kumar et al. (2023) work focus on providing non-repudiation. Blockchain as integrity mechanism is scientifically mature and should be a deployment standard. Blockchain as a privacy-preserving unified compliance system is still a growing research topic.

6.3.2. Compliance auditing in resource-constrained IoT

Current edge computing approaches for IoT security largely treat the edge as a security anchor that offloads heavy cryptography, access control, anomaly detection, and logging from constrained devices to nearby gateways or micro-data centers (Seul and Varol, 2023). Proposed frameworks emphasize placing authentication or AI-based threat detection at or near the edge (Albshaier et al., 2025), so that decisions to block anomalous traffic can be made close to data sources.

These designs create several tensions for security compliance: distributing security logic to edge nodes complicates assurance, because auditors must now trust and verify many intermediate enforcement points rather than a small number of centralized services (Wang et al., 2021). There is also a trade-off between continuous monitoring at the edge and the privacy, bandwidth, and energy costs of collecting detailed telemetry about device behavior (Briliyant et al., 2025). Finally, while edge-based AI promise better attack detection on constrained devices (Pal et al., 2023), their opacity challenge explainability, making it harder to demonstrate compliance in a transparent, evidence-based manner. This explainability problem also complemented by Chung et al. (2024) who highlighted a sense of false security when trusting current explainability tool in ML/DL.

Despite these obstacles, Stream 3 research identifies exponential growth and recommends LLMs (Friha et al., 2024), and multi-agent AI systems (Alevizos, 2025), which inherently computationally intensive, for security auditing. This is not a technical oversight; it reflects the reality that *on-device* compliance checking may be infeasible, requiring architectural redesign.

6.3.3. The raise of AI

It is perceive that in modern computer security there is significant challenge in the growing skill gap as intruder capabilities increase (Sicari et al., 2018), making it necessary to begin automating security compliance. Early effort was proposed by Pozdniakov et al. (2020) and then followed by Chu et al. (2024), developing smart agent that performs security testing to find vulnerabilities in a target system.

As it does so, it accumulates knowledge, learns new sequences and improves its own internal logic using reinforcement learning (Pozdniakov et al., 2020).

This began the agentic approach for cyber security testing. As LLM technology maturing, this agentic approach is replaced by LLM (or SLM) as shown by the works of Deng et al. (2023) and Jin et al. (2024). The problem is, these proposed automation is not auditing, but rather pentesting and vulnerability management. There is one crucial thing missing, that is the audit criteria (regulation, policy, standards).

Multi-agent AI systems for security compliance auditing has been researched in fragment although not for the purpose of automated compliance. For instance, an “extraction” agent that can translate textual norms (for example, GDPR or ETSI EN 303 645) into machine-readable requirements implicitly studied by Zhang and El-Gohary (2016) since 2016, and then perfected using AI by Cejas et al. (2023) and Cadet et al. (2024) in 2024. A “risk assessment” agent can then reasons over this corpus, with NLP or LLM-based components, to determine whether the implemented controls are “appropriate” for the IoT asset and threat model, before a “verification” agent proposes findings, explanations, and evidence chains to human auditors. Recent work on knowledge graph, RAG and LLM in security analysis and conversational audit assistants illustrates this pattern possible in the future (Deldari et al., 2024).

However, several unresolved challenges remain. First, training reliable extraction and risk agents requires gold-standard, labeled interpretations of norms and controls, and such datasets are scarce for most regulations, as investigated by Friha et al. (2024) and Tihanyi et al. (2024). Second, auditors may struggle to trust conclusions that emerge from opaque multi-agent negotiations, especially when LLM-based components introduce hallucinations or non-determinism, a concern highlighted in recent log-analysis (Foalem et al., 2025), firmware (Iqbal et al., 2024), and network traffic (Paduraru et al., 2025) in an LLM-based security.

Be that as it may, the approach is arguably feasible, the use of technology advancements as an assistant to human analyst is very useful for auditor, they can ingest audit data at scale. The works by Deldari et al. (2024) and Paduraru et al. (2025) paved the way to this approach. The caveat is that security auditors will need to be able to trust the assistant (audit tools/CAATs) before they will adopt it, as stated by Galis (2023).

7. Limitations of automated compliance in IoT security

Section 5 highlights the tensions that current research demonstrated. Although technical feasibility through three evolutionary Streams has been evolved: foundational proof-of-concept (Stream 1), scaled approaches (Stream 2), and AI-driven solutions (Stream 3). Yet Section 1 documented that auditor adoption remains stalled at 18%. This section diagnoses why technical capability has not translated to organizational practice, revealing research coverage gaps that reflect in the tensions of current research landscape.

Table 7

Proposed automation approach in IoT security audit.

Study	Category	Automation mechanism	Validation method	Regulatory alignment
Iqbal et al. (2024), Alsubaei et al. (2019), Alevizos (2025) and Cejas et al. (2023)	Compliance in IoT	Automated experiments, rule checking	Empirical study (5+ devices)	HIPAA, CCPA
Khurshid and Raza (2023) and Tauqeer et al. (2022)	Compliance in IoT	Smart contracts, TEE, blockchain	Theoretical framework	GDPR
Rizvi et al. (2020, 2023)	Compliance in IoT	N/A	Conceptual paper	N/A
Dover (2021)	Automation in healthcare IoT	N/A	Theoretical framework	HIPAA
Echenim and Joshi (2023) and Tauqeer et al. (2022)	Automation with knowledge graphs	Knowledge graphs, SPARQL	Conceptual paper	NIST IR 8228, GDPR
Kaksonen et al. (2025)	Automation design	N/A	Theoretical framework	ETSI EN 303
Bicaku et al. (2020)	Industrial IoT	N/A	Empirical paper	IEC 62443
Salva and Blot (2021)	Audit areas with formal methods	Model checking	Theoretical framework	N/A
Alevizos (2025)	Audit areas review	N/A	Automation design	Multiple IoT regulations
Oranekwu et al. (2024)	Audit with knowledge representation	Automated verification, knowledge graphs	Conceptual paper	NIST IR 8259
Slapničar et al. (2022)	Quality metrics	Security-quality metrics	Automation design	N/A
Cha et al. (2023) and Zhang et al. (2024)	Blockchain-based audit	Blockchain smart contracts	Empirical study (simulated)	ISO/IEC 15408-2
Kellogg et al. (2020)	Compliance monitoring	Continuous compliance monitoring	Market study	IEC 62443
Baral et al. (2024)	Self-adaptive systems	Self-adaptive recovery mechanisms	Theoretical framework	NIS Directive, Cybersecurity Act

Table 8

Research coverage across multi-dimensional IoT audit framework.

Audit dimension	Papers	%	Why this coverage?
<i>What capabilities exist (Firmware Analysis)</i> Firmware examination, CVE extraction, vulnerability detection	111	88.8%	Research-friendly: machine-ready standard extraction, offline analysis, reproducible
<i>What devices are configured to do (Configuration Analysis)</i> Device configuration assessment, policy compliance checking	34	27.2%	Requires organizational device access, contextual interpretation
<i>What devices are actually doing (Operational Monitoring)</i> Network traffic analysis, log analysis, behavioral monitoring	22	17.6%	Research-unfriendly: Privacy concerns (IRB), real-time infrastructure, non-reproducible
Network traffic analysis	9	7.2%	Privacy sensitive; context-dependent; infrastructure required
Log analysis	8	6.4%	Sensitive data (GDPR/HIPAA); heterogeneous formats
Behavioral telemetry	5	4.0%	Limited device access; big-data problems; privacy constraints
<i>What behavior means (Contextual/Organizational Analysis)</i> Business process understanding, risk assessment, regulatory interpretation	2	1.6%	Qualitative; requires domain expertise; no clear metrics

7.1. The firmware-centric research imbalance

Research coverage is heavily concentrated on firmware analysis (88.8% of papers), as depicted in Table 8. This concentration does not reflect operational necessity but rather research feasibility and publication incentives. Organizational compliance auditing is fundamentally multidimensional as repeatedly emphasized by Rizvi et al. (2023), Filepp (2018), Nadir et al. (2019), and Kagita et al. (2021): auditors must understand device *capabilities* (what firmware enables), device *configuration* (what administrators chose), device *behavior* (what devices actually do), and *contextual meaning* (whether that behavior satisfies compliance requirements for this organization). Research has comprehensively addressed the first dimension (capabilities); the other three remain underdeveloped.

We argue that the imbalance reflects incentive misalignment. Firmware analysis is *publishable as research*: papers report accuracy metrics such as model checking (Salva and Blot, 2021), CVEs detected (Yu et al., 2023; Iqbal et al., 2024), regulations extracted (Sivakumaran and Blasco, 2021; Cejas et al., 2023), compare algorithms (Ju, 2024), or propose novel techniques (Srivastava et al., 2019) are easily found. But operational monitoring which is inherently *management-focused*: papers describe deployment challenges, integration effort, real-world constraints. These are less investigated. Yet for practitioners, operational dimensions are directly relevant, because auditors must know what devices are *actually doing*, not just what they *could do* (Rizvi et al., 2023). This is where the research-to-practice gap (Tension 1, see Section 5) manifests: research solved the interesting yet feasible technical problem (analyzing firmware); practice requires a different problem (understanding operational behavior). The concentration on

firmware analysis is not accidental; it reflects what research culture rewards.

7.2. What can be automated?

Across Stream 1–3 research, three technical capabilities have achieved operational maturity, demonstrating reproducible, high-accuracy automation suitable for deployment.

7.2.1. Device inventory and configuration baseline

Automated identification of device types, versions, and configurations (Majumdar et al., 2021; Kotak and Elovici, 2023). Fingerprinting techniques such as network scanning (Sivanathan, 2020), MAC analysis (Matsumoto et al., 2021), firmware extraction (Kohli et al., 2024) identify devices with 85%–95% accuracy. Inventory automation is prerequisite for all subsequent audit functions; every device must be identified before it can be assessed.

Why Success: the mechanism offer clear pass/fail logic. For instance, the mechanism crawl the network and check whether Device X is Philips pump version 4.3 OR NOT based on their firmware (Yu et al., 2023; Srivastava et al., 2019). This mechanism required no contextual judgment, and it is directly measurable and reproducible across deployments.

Operationally: This capability is already deployed routinely, especially in firmware dimension (Iqbal et al., 2024). Organizations scan networks, extract device inventories, and track configurations. Automation here is uncontroversial.

7.2.2. Signature-based violation detection

Identifying known-bad patterns: deprecated protocols (SSLv3, TLS 1.0), weak cryptography (MD5, DES), default credentials, unpatched versions. Detection relies on comparing device configuration against known-bad signatures.

Evidence: >95% accuracy across 20+ years of operational deployment (antivirus engines, SCAP-based scanning, intrusion detection systems). Multiple papers such as Vutukuru (2023) and Alattas et al. (2022) report consistent 90%–98% accuracy.

Why Success: Vulnerability knowledge is externally validated. If CVE-2024-1234 affects Device X, this is factual; auditor judgment is not required beyond confirming device is vulnerable.

Operationally: Widely deployed as SCAP scanners (although limited only in IT context because of the dependency of device specifications by NIST) to conduct vulnerability assessment (Hassani et al., 2021; Flores and Mugarza, 2018). Auditors integrate this capability in SIEM e.g. Wazuh routinely (Dong and Tian, 2021).

7.2.3. Rule-based compliance checking against machine-readable standards

Verifying device configurations against explicit rules: “Is TLS 1.3 enabled?” “Are certificates current?” “Is default admin password changed?” OSCAL/SCAP frameworks enable this automation by representing requirements as executable rules (Konstantinidis, 2017; Varela-Vaca et al., 2019), certificate-based attestation of compliance also highly researched (Baldini et al., 2016), especially in the cloud ecosystem (Lins et al., 2018). It even developed to a certificateless attestation but mostly still in cloud environment (Burra and Maity, 2022).

Evidence: 99%+ accuracy when requirements are precisely specified and machine-readable. Federal systems using OSCAL/SCAP achieved 30%–40% compliance cost reduction (Slapničar et al., 2022).

Why Success: Rules are objective. The verification of “Are certificates valid?” has definitive answer: yes or no, and will be checked automatically.

Limitation: Works only when standards are machine-readable and requirements are precisely specified (Scarfone et al., 2021). That is why most OSCAL adoption remains limited outside federal systems (FISMA, FedRAMP). Healthcare, financial, manufacturing sectors lack equivalent standardization and specification for their edge devices.

Certificate-based compliance attestation mostly relevant to cloud environment, because the cloud introduces a fundamental “trust gap” that does not exist in traditional on-premise setups (Cirne et al., 2022).

Is it “really” auditing? This is a point of significant tension in the literature. In the traditional sense, Matheu et al. (2021) argue it is part of auditing. While Al-Matari et al. (2021) insisted that a traditional audit involves a human exercising professional skepticism and gathering independent evidence. Certificate-based attestation is “automated Verification”.

Operationally Proven: Federal agencies deployed OSCAL/SCAP at scale (Costin, 2015). Cloud providers conduct certificate-based attestation regularly (Lins et al., 2018). For now, IoT systems lack standardized control libraries and governance frameworks to adopt OSCAL and certificate-based verification widely.

These findings suggested that the primary barrier to automated IoT compliance is structural rather than technological. While machine-readable frameworks like OSCAL are highly scalable in enterprise environments, they inherently dependent on standardized control baselines to function. Until the highly fragmented IoT ecosystem establishes unified security libraries and governance standards, these proven auditing tools cannot be successfully adapted for the edge.

7.3. What cannot be automated?

Three decision types remain fundamentally dependent on: subject matter expertise, contextual knowledge, and professional judgment. For now, these cannot be automated without losing audit integrity.

7.3.1. Contextual risk assessment

Finding: Telnet protocol enabled on Device X.

Automation Says: Violation. Telnet is deprecated (unencrypted, weak authentication). Policy requires encrypted protocols (SSH).

Auditor Judgment: Device X is in isolated lab network, used by 2 authorized engineers for testing. Telnet is acceptable compensating control (network isolation provides confidentiality; weak authentication risk is mitigated). Violation is not a practical risk.

Alternatively: If Device X is internet-accessible medical device, then Telnet enabled is critical vulnerability that should be remediate immediately.

Why Automation Fails: Context is not pre-specifiable. Risk depends on organizational architecture, business function, and threat model (Jaigirdar et al., 2021). Context emerges from auditor knowledge of systems, not from static rules. Less than 5% of papers attempt context integration such as knowledge graphs (Hosseini et al., 2025; Kholgh and Kostakos, 2023), semantic approaches (Sivakumaran and Blasco, 2021; Zheng et al., 2022), NLP-based (Gokhan et al., 2024), and even RAG (Kurniawan et al., 2022) is proposed but still unvalidated, or at least attached minimum metrics for validation (context recall and context precision). Although, for contextual security analysis (not specifically for IT auditing context), the works by Ju (2024) and Fayyazi et al. (2024) show validation of RAG system by using a special RAG-based metrics (focusing on traceability of context).

7.3.2. Compensating risk control analysis

Finding: Legacy medical device lacks of encryption capability, while security policy requires “implementing strong encryption”. Device inherently cannot comply because of outdated device but to update, there are risks of disruption because of other process dependencies.

Automation Says: Rule has been violated, thus a non-compliant finding.

Auditor Judgment: Device operates on an air-gapped network (no internet connection). Furthermore, physical network isolation provides equivalent protection to encryption. So, the compensating control satisfies the requirement, and risk-equivalent compliance is achieved.

Why Automation Fails: Compensating controls require understanding business architecture, threat models, and risk tolerance. These are

Table 9
Limitations of IoT automated compliance.

Decision type	Automatable?	Evidence	Limitation
Device identification	YES	85%–90% accuracy	Fingerprinting, reproducible
Known-bad pattern detection	YES	>95% accuracy	External CVE knowledge, 20+ years operational
Rule-based checking (precise standards)	YES	99%+ accuracy	OSCAL/SCAP, applied at federal scale
Contextual risk assessment	NO	<5% of papers attempt	Requires organizational knowledge
Compensating control validation	NO	0% of papers address	Requires architecture understanding
Regulatory interpretation	PARTIAL	27% of papers attempt	LLM accuracy 85%–95%; evolving standards
Professional judgment	NO	By definition	Auditor responsibility non-delegable

qualitative judgments, very difficult to be mimicked by algorithmic decisions. **Zero papers** explicitly address compensating control logic.

Table 9 summarizes auditing task that can be automated versus the ones that cannot be automated.

7.3.3. Regulatory interpretation

Finding: GDPR Article 32 requires “encryption of personal data”. Device uses AES-128. Is this compliant?

Automation Says (Stream 3 using LLM approaches): “encryption of personal data” typically interpreted as the use of encryption AES-256 or equivalent. The use of AES-128 may be insufficient and would likely resulted non-compliant (85%–95% accuracy in requirement extraction Hildebrandt et al., 2024).

Auditor Judgment: GDPR permits “appropriate” encryption according to the perceived risk per Article 32 context. For low-sensitivity data, AES-128 may be appropriate. For sensitive data, AES-256 required. Additionally, regulatory interpretation evolves. That is why the ENISA guidance was updated in 2024 on cryptographic strength. Another example: GDPR enforcement practices vary by national regulator. These dynamics made it so the Auditors must keep current with regulatory evolution and jurisdictional differences.

Why Automation Fails: Regulatory requirements are ambiguous and evolving. Standards are updated when knowledge improves or threats change. LLM-based extraction (27% of papers address) such as Paduraru et al. (2025) and Ghosh et al. (2024) captures one interpretation frozen at training time. Real-time regulatory evolution cannot be automated.

Additionally, auditor responsibility is not delegable. ISACA Code of Ethics standards (ISACA, 2019) require auditors to understand and be responsible for audit conclusions. Black-box AI violates this standard implicitly. Explainability and auditability is mandatory for professional compliance (yet 66% of Stream 3 papers lack explainability).

The automation boundary is clear: technical facts like device type, known vulnerabilities, rule violations are automatable. Contextual judgments, compensating controls, and regulatory interpretation remain human decisions requiring professional expertise.

7.4. OSCAL/SCAP: a paradigm shift in automated compliance

The Open Security Controls Assessment Language (OSCAL) and Security Content Automation Protocol (SCAP) represent a meaningful architectural shift in compliance automation, moving organizations away from manually interpreting hundreds of pages of fragmented regulatory documentation toward a unified, machine-readable framework. Rather than maintaining separate compliance programmes for HIPAA, NIST, and PCI-DSS, organizations can consolidate requirements into a single OSCAL profile that tools can reason across simultaneously, with SCAP components handling the automated verification layer through standardized benchmarks and system checks.

Despite this potential, adoption beyond federal contexts remains constrained not by technological immaturity but by an infrastructure and governance gap: most healthcare, financial, and manufacturing organizations heavily rely on standardized control libraries (provided by regulator) needed to operationalize these frameworks at scale.

Case study: Infusion pump compliance assessment

To demonstrate realistic compliance automation, this section presents a healthcare organization deploying 50 connected infusion pumps requiring compliance with HIPAA §164.308(a)(4)(ii)(C) (Administrative Safeguard). Using OSCAL/SCAP, the organization consolidates three separate compliance programs into unified verification.

Process flow: OSCAL Profile (23 tailored controls) will be written in SCAP XCCDF (automated rule specification) format. This rule will be compared against device configuration, network traffic, and logs to find violation or non-compliance. Then, OSCAL assessment results (structured findings, remediation guidance) will be reported through dashboard, complete with audit evidence and remediation tracking.

Fig. 5 illustrates the integrated workflow, showing how OSCAL and SCAP components interact to enable automated compliance checking from planning through evidence generation.

Efficiency Results: Assessment tool completed compliance verification in 4 h (scanning, data collection, analysis). However, total audit effort including human validation, remediation planning, and stakeholder communication remained necessary.

Critical Insight: Despite the assumed time reduction (approx.80%), hours of human audit work remained unavoidable. Humans conducted requirement validation, false-positive review, remediation method selection, and stakeholder communication. Automation eliminated routine checking; professional judgment remained essential. This proves that *automation augments, not replaces, auditors*.

Limitations: The case assumes infusion pump manufacturers provide SCAP-aligned documentation (uncommon), network access to device configurations even edge devices are monitored seamlessly, and OSCAL/SCAP reporting deployment are automate, while in reality many organizations still use manual processes (Waltermire and Fitzgerald-McKay, 2018).

8. The adoption barrier

Section 5 identified four research tensions in the IoT continuous auditing landscape. This section shows how they directly prevent organizational or practical adoption despite demonstrated technical capability.

8.1. Barrier 1: Tool complexity

Tension: Stream 1 and 2 optimizes for technical sophistication (formal method, process mining) rather than operational simplicity. Except for rule-based and certificate-based solution in cloud environment that are established in practice. Stream 3 research brings a new kind of efficiency (LLMs, federated learning, multi-agent systems) in a heterogeneous and dynamic IoT system, but rarely involving human auditor participation.

Barrier: Section 1 stated that 71% of organizations cite “tool complexity” as adoption barrier (PricewaterhouseCoopers, 2025).

Root Cause Mapping: Sophisticated solutions require multiple tool integrations, but each integration requires specialized staff (DevOps, data engineers, auditors). Usually, adding more specialized staff is expensive and rare, many organizations avoid this. In more personal context, professions like IT auditors uphold code of conduct more than


```

<!-- OSCAL Profile: Unified Requirements (23 tailored controls) -->
<profile>
  <import href="nist-800-53-rev5-catalog.xml"/>
  <constraint>TLS 1.3+ for all pump communications (HIPAA); AES-256 for sensitive
    data (FDA)</constraint>
</profile>

<!-- SCAP XCCDF: Automated Verification Rules -->
<Benchmark id="healthcare_infusion_pump_benchmark">
  <Group id="group_encryption">
    <Rule id="rule_tls_version" selected="true">
      <title>TLS Version Compliance</title>
      <check system="oval"><check-content-ref href="infusion-pump-checks.xml"
        name="oval:healthcare:def:1001"/></check>
      <fixtext>Upgrade firmware to v4.3+ (TLS 1.3 support). Effort: 2 hours.</fixtext>
    </Rule>
  </Group>
</Benchmark>

<!-- OSCAL Assessment Results: Structured Findings -->
<assessment-results>
  <findings>
    <finding uuid="finding-001">
      <title>Infusion Pump Device-A: TLS Version Mismatch</title>
      <description>Device uses TLS 1.2; requirement is TLS 1.3+</description>
      <control-id>sc-7</control-id>
      <severity>HIGH</severity>
      <remediation>
        <description>Upgrade firmware to v4.3+</description>
        <estimated-effort>PT2H</estimated-effort>
      </remediation>
    </finding>
  </findings>
  <control-assessment control-id="sc-7">
    <status>PARTIAL_COMPLIANCE</status>
    <percentage-compliant>80.0</percentage-compliant>
  </control-assessment>
</assessment-results>

```

Fig. 5. OSCAL/SCAP integrated workflow for infusion pump compliance.

anything, they will use tool that can help them achieve that goal, but user-friendly features are always helpful.

Research Response: Only 5.7% of papers address user participation study. Most solutions (Oranekwu et al., 2024; Pozdniakov et al., 2020) are focusing on automation without knowing what the functional requirements are from the actual auditors. Auditors face irrelevant automation, or hard to use solution.

8.2. Barrier 2: ROI uncertainty

Tension: Research has accelerated (42 papers during 2024–2025) although without real-world validation. Simulation and lab results provide no evidence of how adoption impacts actual organizational performance.

Barrier: 58% of organizations cite “cost” or uncertainty about financial returns as adoption barrier (PricewaterhouseCoopers, 2025).

Root Cause: Organizations lack deployment-context economic evidence. Research provides lab-validated accuracy metrics (up to 99%) but zero organizational-context data enabling local ROI calculation.

Business investment decisions follow a standard capital budgeting formula called the *Net Present Value (NPV)*. It was formalized and popularized by Irving Fisher in his 1907 work, *The Rate of Interest*.

$$NPV = \sum_{t=0}^n \frac{CF_t - C_t}{(1+r)^t} \quad (1)$$

where: CF_t = cash flow benefit (time savings), C_t = deployment cost, r = cost of capital, n = project lifetime.

Organizations cannot calculate CF_t (time savings benefit) or C_t (implementation cost) from research evidence because research is silent on organizational-context factors that determine these values.

- **Baseline Audit Effort (determines CF_t):** How many hours does compliance auditing consume in *their* organization? Research does not address this. Automation benefit (time freed) scales directly with baseline. An organization with 2000 baseline hours sees \$160K benefit (2000 h × 80% reduction × \$100/hr loaded cost). Same tool saves \$800K in large organization. Research cannot predict this without knowing organizational context.

- **Implementation Cost (determines C_t):** What is the true all-in cost for *their* organization? Research provides none or wildly optimistic estimates.

Why This Matters for Adoption: Organizations need a local NPV calculation, not a generic claim.

The practical consequence is predictable. When organizations lack reliable input parameters, they apply conservatively pessimistic assumptions (Kahneman and Tversky, 1979). A realistic organizational assessment might assume 50% time reduction (rather than the researched 82%), total costs of \$400K (double the vendor estimate, to account for integration risk), and an 18-month adoption horizon rather than the near-instantaneous benefit implied by simulated evaluation. Under these assumptions, the break-even point shifts from approximately two months (the figure implied by research optimism) to 12 months under organizational realism.

Empirical Evidence: only 1.6% of papers attempt this Markina et al. (2021) and Hanson and Straub (2024). Organizations rationally cannot commit investment without it. This is not “cost concerns”, this is *parametric uncertainty preventing capital budgeting*.

8.3. Barrier 3: Generalizability gap

Tension: In risk of bias assessment, we found that generalization bias is high, 89% of papers claim broad IoT applicability, but only 3.2% demonstrate it (Section 4.2).

Barrier: Auditors rationally discount generalizability claims, reducing adoption likelihood.

Why This Matters: Auditor reads: “Framework applicable to all IoT systems” but discovers that it validated only in healthcare simulation. Immediately auditor assume that claims exceed evidence and decide to avoid investment in unproven technology.

Empirical Evidence: Papers exhibit systematic overstatement. Examples from our corpus:

- Bella et al. (2023) claims ontology-driven compliance is “universally applicable to any regulatory standard”. Validation: GDPR subset only.

Table 10
Adoption barriers.

Evaluation dimension	Papers	Why it matters for adoption
Accuracy (up to 99% claimed)	91.4%	Necessary but insufficient; no one uses tools they do not understand
Explainability (SHAP, LIME)	34.3%	Auditors need to explain to regulators: “Why device flagged?” Without XAI, answer is “AI said so”
Fairness assessment	14.3%	ML systems can systematically discriminate across device manufacturers. Undetected bias = legal liability
User studies	5.7%	Never tested with actual auditors. No evidence tools are usable or acceptable
Organizational context	1.6%	Does not have context in real organizations to prove efficacy

- [Ju \(2024\)](#) applies RAG and regex matching for wearable device logs, claims “direct applicability to IoT”. Validation: wearables only, no industrial IoT, no consumer IoT.
- Multiple papers ($n = 15$, 12% of corpus) make explicit general-purpose claims (“applicable across all IoT domains”) but validate on single device type or single regulatory standard.

This is a documented pattern in the literature: 89% claim broad applicability; 3.2% demonstrate it. This gap itself represents a research integrity concern (publication bias toward optimistic claims).

8.4. Barrier 4: AI without explainability blocks trust

Tension: Stream 3 papers achieve high accuracy (91.4%) but lack foundational trust evaluation: explainability (34.3%), fairness assessment (14.3%), user studies (5.7%) (see [Table 10](#)).

Barrier: Auditors cannot defend AI-generated findings to regulators, so they distrust tools.

Translation to adoption reality: Paper claims: “99% accurate AI for compliance”; Auditor’s question: “Why was Device X flagged as non-compliant?”; AI: [silence; black box]; Auditor: “Can’t defend this to regulators”; Auditor: [doesn’t use tool]; Adoption: No.

8.5. How barriers interact

Stream 1–2 research advanced algorithmic approaches to standards interpretation ([Abu-Tair et al., 2024](#); [Beach et al., 2020](#)), control verification through process mining ([Turner, 2022](#); [MacAk et al., 2020](#)), and formal methods ([Bicaku et al., 2020](#); [Majumdar et al., 2021](#)) for compliance reasoning. These technical advances are genuine contributions. However, this research trajectory emerged from disciplinary incentives, more academic publications reward algorithmic novelty, rather than from auditor requirements.

According to [Hillo and Weigand \(2016\)](#), organizations struggling with the adoption of continuous auditing face a multifaceted landscape of uncertainties. Firstly, they grapple with complex functional requirements, which constitute “Barrier 1”. This is further complicated by unpredictable financial outcomes, forming “Barrier 2”, where the return on investment remains uncertain. Thirdly, “Barrier 3” reflects concerns about the generalizability of solutions to their specific operational contexts. Finally, “Barrier 4” encompasses issues of unproven trustworthiness and professional acceptability, particularly concerning AI-driven tools.

We argue that when these four tensions converge, the rational response from organizations and auditors as the user is one of conservative caution. Faced with such coordinated uncertainty, investment in these advanced solutions is inevitably deferred, leading to a stalled adoption rate ([KPMG, 2023](#)). The paradoxical aspect of this situation, as highlighted in [Flowerday et al. \(2006\)](#) is that further technical innovation, such as more sophisticated AI, can exacerbate this adoption gap. For instance, highly advanced AI (e.g., Large Language Models, federated learning, multi-agent systems) can reduce integration complexity, addressing Barrier 1, but at the same time provided no explainability and auditability, worsening Barrier 4. Moreover, such

innovation frequently fails to address crucial organizational change management factors (worsening Barrier 2) and does not inherently promote multi-domain validation (worsening Barrier 3).

9. Discussion

The analysis of the corpus reveals a fundamental paradox: *automation technology advances and accuracy soar, but implementation stalls*. Our analysis suggest that adoption barriers emerge from specific research tensions. Understanding this tension-barrier chain clarifies the adoption gap. [Table 11](#) provides a problem-solution map, with prioritization, explicit standards relevance, how to integrate in the audit workflow stages (if applicable), and measurable evaluation metrics.

9.1. Misaligned research focus

The corpus reveals a systematic prioritization of technical performance over auditor-centered evaluation. Stream 1 and 2 research prioritized understanding regulatory standards through semantic engineering and formal methods ([Bicaku et al., 2020](#); [Majumdar et al., 2021](#)), or verifying controls through SCAP/OVAL frameworks ([Waltermire and Fitzgerald-McKay, 2018](#)). These approaches are intellectually sophisticated and publishable, but they result in complex deployments requiring specialized personnel. Knowledge-based systems (Stream 3 research) represent perhaps the most advanced instantiation of this trend, incorporating artificial intelligence capabilities to interpret complex regulations and apply them across varied IoT implementations ([Anselmi et al., 2023](#); [Echenim and Joshi, 2023](#)). These systems encode regulatory requirements and organizational policies into machine-readable formats, enabling automated reasoning ([Bella et al., 2023](#)). Yet this sophistication still carries an adoption burden: 71% of organizations cite tool complexity as their primary adoption obstacle. Although, worth mentioning that this proposed solution is still 2–3 years old, so it is hard to judge its resistance while the technology is still maturing.

Only 5.7% of papers involved practicing auditors in design, displaying critical gap in the research landscape that lacked human-centered methodology and psychology perspectives. [Deldari et al. \(2024\)](#) and [Foalem et al. \(2025\)](#) conducted user studies with auditors and found explainability and intuitive interface design are prerequisites for adoption, not technical sophistication. This suggests that HCI simplification is more valuable than high accuracy. This means research that did not address how auditors form trust judgments about auditing tools directly affects adoption. Thus, **Tension 1 (T1)** manifests as **Barrier 1 (B1)**: *tool complexity blocking adoption despite technical capability*.

9.2. Non-technical aspects affect ROI uncertainty

Stream 3 research (2024–2025) produced 42 papers in two years, a pace that reflects publication pressure but narrowed evaluation focus to technical metrics. While 91.4% of papers report accuracy, only 33.3% address explainability, 14.3% assess fairness, and 4.8% include

Table 11
Relations between adoption barrier, research gap, and proposed future direction.

Research topic	Tension-Barrier	Priority	Related standards	Audit workflow	Gap	Evaluation metrics
HCI & audit tool complexity	T1→B1	High	AICPA TQA 8400; IIA GIAS 2024 10.3	Audit data ingestion, Verification, Reporting	User studies only 4.8%	SUS score ≥ 70 ; task completion ≤ 60 min; user satisfaction $\geq 4/5$
Multi-dimensional coverage	T1, T3→B1, B4	Medium	N/A	Planning, Verification	Firmware-centric coverage 88.8%	Cover more: IoT network, IoT logs, IoT telemetry.
Organizational context & ROI	T2→B2	Medium	N/A	N/A	approx. 90%+ technical automation	Time savings (hrs/audit); cost reduction (see 8.2).
IoT domain generalizability	T3→B3, B4	Low	ISO 19011:2018 (clause 5.5.3)	Planning	28:1 claim-evidence gap	Cross-domain recall/precision; context impact; IoT protocol based.
Explainability & fairness	T4→B4	High	NIST AI RMF, ISACA Code of Ethics #2	Verification (findings); Reporting (auditor defense)	Explainability 34.3%; Fairness 14.3%	Traceable evidence; faithfulness & fairness metrics ≥ 0.7 ; user acceptance $\geq 80\%$.
Change management	T2→B2, B3	Low	N/A	N/A	No coverage, but could address commitment	Business process modeling; ROI; stakeholder satisfaction.
Cross-disciplinary integration	All	Low	N/A	Planning	CS-only discipline	Citation rate; funding alignment.

user studies with practicing auditors, indicating that what is fastest-to-publish model dominates over what necessary but harder: interpretability, non-discrimination, and usability in real audit practice. As a result, 83% of studies validate tools only on technical dimensions, leaving non-technical factors such as business process integration, change management, staffing implications, infrastructure dependencies, and financial viability essentially unexamined. Gokhan et al.'s (2024) work on governance challenges in digital compliance illustrates this gap: it diagnoses governance issues but does not offer a concrete change-management methodology or costed transition path.

Recent GRC research highlights the strategic importance of integrated governance, risk, and compliance frameworks but provides limited quantitative evidence on the economics and ROI of technology-enabled compliance automation. Building on Avianti and Handoyo's (2025) bibliometric study of 429 GRC articles, which finds growing interest in digitalization (e.g., AI, blockchain) yet little empirical work on cost structures or investment outcomes, this paper therefore draws on practitioner sources to fill that gap.

Because peer-reviewed work has not yet converged on standard benchmarks for compliance-automation investment levels, we treat large-scale vendor surveys and sectoral case studies—such as Secureframe's (Bonnie, 2025) survey of 160+ organizations and fintech-focused analyses (Thakur, 2025) of AI-enabled compliance—as pragmatic empirical inputs for calibrating plausible ROI ranges. While acknowledging that such sources must be interpreted critically given their commercial provenance, it is worth noting that vendor case studies frequently reported positive ROI within roughly 12–24 months of automation implementation.

The academic-industry research gap directly manifests as **Barrier 2 (B2)**: *organizations cannot confidently estimate time savings or adoption costs*. Only small numbers of papers such as Hanson and Straub (2024) and Markina et al. (2021) quantify auditing implications (non-compliance sanctions, disrupted business processes). Without this evidence, conservative organizational budgeting prevails, investment in uncertain value is deferred.

9.3. Unvalidated claims widen interoperability gaps

While Rizvi et al. (2023) demonstrates that IoT compliance frameworks can address shared technical layers (firmware, network, telemetry, physical), this does not automatically translate to deployment generality across IoT domains. A 28:1 gap exists between papers claiming broad applicability (89%) and those demonstrating multi-domain validation (3.2%). Bella et al. (2023) claims ontology-driven compliance is universally applicable to any regulatory standard but validates

only on GDPR subsets; Ju (2024) applies RAG and *regex matching* for wearable devices logs yet claims direct applicability to IoT without further evidence. This systematic overstatement erodes credibility. Additionally, only 8.8% propose interoperability solutions with existing tool ecosystems (SCAP/OpenSCAP, SIEM platforms, ERP), creating siloed solutions requiring custom integration. These gaps manifest as **Barrier 3 (B3)**: *credibility erosion*. Auditors rationally assume narrow applicability and high integration costs, justifying avoidance.

9.4. Auditors' professional mandates

A recurring tension in Stream 3 is that “accuracy” is treated as sufficient evidence of tool utility, while the professional obligations that govern audit practice are absent from research design entirely. AICPA and ISACA standards require auditors to understand and evaluate the evidence underpinning their conclusions and to *bear personal responsibility* for audit findings; delegation to an unexplained model is not professionally permissible. Yet explainability is addressed in only 33.3% of AI papers, fairness assessment in 14.3%, and auditor user studies in 4.8%, with traceability and auditability requirements unaddressed across the corpus. Asaad et al. (2025) represents the sole exception treating explainability as a compliance-context requirement, and Deldari et al. (2024) empirically confirms it as critical to adoption; the remainder validate against algorithmic benchmarks that carry no professional weight. This gap is compounded by Chung et al.'s (2024) finding that explainable AI methods themselves frequently produce erroneous or misleading explanations, suggesting that the minority of papers addressing explainability may be overstating the assurance they provide.

The professional liability dimension makes this more than an academic gap. Where an AI system exhibits algorithmic bias, auditors who report those findings bear liability under IIA professional standards (IIA, 2025). No paper in the IoT compliance corpus addresses this risk. Murikah et al. (2024) documents the broader absence of rigorous fairness benchmarking in AI-assisted auditing, and emerging responsible AI frameworks (Berengueres, 2024; Xia et al., 2024) offer metrics catalogues that begin to address accountability, but none have been used in an IoT audit context. High accuracy is a necessary but insufficient condition for professional adoption; trust requires concurrent evidence of explainability, fairness, and standards alignment that the literature does not yet supply, constituting **Barrier 4**: a trust deficit that accuracy metrics alone cannot resolve.

9.5. Why auditors reluctant to adopt research?

These four tensions do not act independently; they compound into coordinated adoption gap. Organizations evaluating continuous compliance adoption simultaneously face: (1) complex integration requirements (B1), (2) unpredictable financial outcomes (B2), (3) uncertain generalizability to their context (B3), and (4) unproven trustworthiness and professional acceptability (B4). [Table 11](#) maps how research tensions create adoption barriers and identifies roadmap opportunities to resolve them.

Paradoxically, further technical innovation worsens this coordination failure. More sophisticated tools (LLMs, federated learning, multi-agent systems) could increase user complexity (worsening B1), often reduces explainability through greater algorithmic opacity (worsening B4), and does not address organizational change management factors (stagnating B2). It even could not promote generalizability (not doing much for addressing B3). The path to adoption requires not more tech innovation but rather realignment in how research is conceptualized, evaluated, and designed.

9.6. Implications for future works

The systematic review yields five actionable redirections for research priorities:

Simplification over sophistication. Rather than pursuing higher accuracy or more advanced technology, research should focus on achieving good accuracy with equally good SUS (System Usability Scale) score. This directly addresses **Barriers 1** and **5** (tool complexity and skill gaps). HCI-informed tool design should become the primary metrics for impact rather than higher accuracy.

Trust-driven evaluation is mandatory. Papers claiming practical impact should require explainability (auditors can explain findings), fairness assessment (no algorithmic discrimination), user studies ($n \geq 20$ practicing auditors), and professional standards alignment (AICPA/IIA compliance). Accuracy alone is insufficient. This addresses **Barrier 4** (trustworthiness).

Organizational context as prerequisites. Simulation validation is necessary but not enough as also saturated. Organizations require evidence that solutions work in a use case business contexts. Research need to address more organizational context such as financial modeling (simulate ROI), or simulated audit workflow automation. This addresses **Barrier 2** (ROI uncertainty).

Cross-domain research. A useful way to tackle **Barrier 3** (generalizability across IoT domains) is to reframe future research around cross-domain invariants rather than domain-specific use cases. Protocol and stack layers that already span smart home, building automation, and industrial such as MQTT, CoAP, and Modbus provide natural abstraction points for compliance security controls that can be re-used across sectors.

Worth noted that in [Table 11](#) we assign HIGH PRIORITY for two research topics: *HCI & tool complexity*, and *explainability & fairness*. This is because we argue that in the near future, addressing these two topics would accelerate adoption based on two logic: (1) technological readiness is proven that accuracy is high but *explainability still low*; (2) many automated compliance solutions today focus on audit data aggregation (audit trails), but auditors need impactful solution in *analyzing these data with trust*.

However, for the long game, closing the adoption gap requires research realignment: field validation, multi-domain coverage, ROI modeling, and cross-disciplinary collaboration. The technology is ready; practical adoption awaits research alignment.

9.7. Threats to validity

This systematic review follows PRISMA 2020 guidelines to ensure transparency and reproducibility. However, several validity threats and limitations constrain the generalizability of findings:

9.7.1. Publication bias

Papers in the corpus exhibit strong publication bias toward AI-driven solutions (Stream 3: 42 papers, 33.6% of all 125 papers, published 2024–2025 only). This concentration increased from Stream 2 (54.4%, 68 papers, 2021–2023) despite Stream 2 developing mature ML approaches. The spike reflects LLM popularity in machine learning community, not evidence of superior capability for compliance auditing. Our count of 91.4% papers reporting accuracy metrics may reflect publication selection prioritizing quantifiable technical metrics over organizational outcomes. The scarcity of papers reporting organizational-context data (1.6%) may reflect publication barriers rather than researcher disinterest. We included grey literature (arXiv preprints, $n = 15$ papers, 12% of corpus) to capture research not yet published in peer-review venues, reducing (but not eliminating) publication bias.

9.7.2. Language bias

Our search strategy was restricted to and English-language publications. Regions with significant IoT research and different regulatory contexts (e.g., China, Brazil, Southeast Asia) likely conduct substantial research in local languages (Mandarin, Portuguese, Thai, etc.). Our corpus is biased toward English-speaking researchers and Western regulatory contexts.

9.7.3. Limitations

The adoption gap analysis relies on three industry surveys ([KPMG, 2023, 2024](#), [PWC 2025 PricewaterhouseCoopers, 2025](#)) that share methodological constraints: sample sizes are modest (approximately 240–500 respondents), definitional consistency across the construct of “adoption” is not guaranteed, and coverage skews toward North American and European organizations. Furthermore, manual screening inevitably introduced interpretive judgement at boundary cases due to the review team’s background in computer science and IT audit (not organizational behavior).

Taken together, these constraints suggest that the corpus characterization findings carry low validity risk, while adoption barrier analysis and any extrapolation to non-Western deployment contexts should be interpreted with moderate-to-high caution.

10. Conclusion

IoT ecosystems improve business efficiency but introduce massive cybersecurity and regulatory risks across heterogeneous device networks. These vulnerabilities can have severe consequences, including data privacy breaches and compromised cyber-physical infrastructure, necessitating robust continuous auditing mechanisms. Automated security compliance tools offer a promising solution by shifting governance from point-in-time checks to real-time verification. The main contribution of this paper is a comprehensive systematic survey of 125 papers that represent current automated compliance approaches for IoT environments. Our review identify technological evolution from foundational rule-based and blockchain systems (15 papers), to machine learning and edge computing consolidation (68 papers), and emerging LLM and multi-agent AI transformations (42 papers). Moreover, we critically analyzed the trajectory of these approaches through the lens of the auditor’s cognitive workflow. We identified a prevalent gap in the current literature, where optimizing purely for technical detection metrics fails to provide the legally defensible, explainable evidence required by compliance professionals. Additionally, we mapped the distribution of these solutions across critical domains, emphasizing the gap between academic algorithm development and practical business adoption. Lastly, we present actionable future research directions, emphasizing a necessary shift from autonomous task replacement to intelligent augmentation, guiding the development of deployable, AI-assisted continuous auditing frameworks.

CRediT authorship contribution statement

Obrina Briliyant: Writing – review & editing, Writing – original draft, Visualization, Software, Data curation, Conceptualization. **Amir Javed:** Methodology, Writing – review & editing. **Yulia Cherdantseva:** Methodology, Supervision.

Declaration of Generative AI and AI-assisted technologies in the writing process

During the preparation of this work, the authors used Gemini 3.1 Pro Preview in order to improve readability and language. The authors reviewed and edited the content as needed and take full responsibility for the content of the publication.

Declaration of competing interest

The authors declare the following financial interests/personal relationships which may be considered as potential competing interests: O. Briliyant reports financial support was provided by Indonesia Endowment Fund for Education (LPDP). Other authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Acknowledgments

This research is fully funded by the Indonesia Endowment Funds for Education (LPDP) under grant #685/CBS/ D/ASN.

Data availability

No data was used for the research described in the article.

References

- Abu-Tair, M., Ali, A., Gebresilassie, S.K., Rafferty, J., Cui, Z., 2024. Regulation compliance system for IoT environments: GDPR compliance as a use-case. In: Barolli, L. (Ed.), *Advanced Information Networking and Applications*. Springer Nature Switzerland, Cham, pp. 147–160. http://dx.doi.org/10.1007/978-3-031-57853-3_13.
- Al-Karaki, J.N., Gawanmeh, A., El-Yassami, S., 2022. GoSafe: On the practical characterization of the overall security posture of an organization information system using smart auditing and ranking. *J. King Saud Univ. - Comput. Inf. Sci.* 34, 3079–3095. <http://dx.doi.org/10.1016/j.jksuci.2020.09.011>.
- Al-Matari, O.M., Helal, I.M., Mazen, S.A., Elhennawy, S., 2018. *Cybersecurity Tools for IS Auditing*. Institute of Electrical and Electronics Engineers Inc, pp. 217–223. <http://dx.doi.org/10.1109/ES.2018.00040>.
- Al-Matari, O.M., Helal, I.M., Mazen, S.A., Elhennawy, S., 2021. Integrated framework for cybersecurity auditing. *Inf. Secur. J.* 30, 189–204. <http://dx.doi.org/10.1080/19393555.2020.1834649>.
- Alattas, H.T., AlMahasheer, N.R., Alswaidan, H.A., Almoqbel, M.A., 2022. Extract compliance-related evidence using machine learning. In: *2022 14th International Conference on Computational Intelligence and Communication Networks. CICN*, <http://dx.doi.org/10.1109/cicn.2022.91>.
- Albshaier, L., Almarri, S., Albuali, A., 2025. Federated learning for cloud and edge security: A systematic review of challenges and AI opportunities. *Electronics* 14 (5), 1019. <http://dx.doi.org/10.3390/electronics14051019>, URL: <https://www.mdpi.com/2079-9292/14/5/1019>, Publisher: MDPI AG.
- Alevizos, L., 2025. Automated cybersecurity compliance and threat response using AI, blockchain and smart contracts. *Int. J. Inf. Technol.* 17 (2), 767–781. <http://dx.doi.org/10.1007/s41870-024-02324-9>, URL: <https://link.springer.com/10.1007/s41870-024-02324-9>, Publisher: Springer Science and Business Media LLC.
- Alromaih, A., Ismail, Y., Elmedany, W., 2022. Continuous compliance to ensure strong cybersecurity posture within digital transformation in smart cities. In: *6th Smart Cities Symposium. SCS 2022*, Vol. 2022, pp. 464–479. <http://dx.doi.org/10.1049/icp.2023.0647>, URL: <https://ieeexplore.ieee.org/document/10137541>.
- Alsubaie, F., Abuhusseini, A., Shandilya, V., Shiva, S., 2019. IoMT-SAF: Internet of medical things security assessment framework. *Internet Things (Netherlands)* 8, <http://dx.doi.org/10.1016/j.iot.2019.100123>.
- Anselmi, G., Mandalari, A.M., Lazzaro, S., Angelis, V.D., 2023. COPSEC: Compliance-Oriented IoT Security and Privacy Evaluation Framework. *Association for Computing Machinery (ACM)*, pp. 1–3. <http://dx.doi.org/10.1145/3570361.3615747>.
- Asaad, A., Chy, A.M.A.H., Kabir, A.S., Nakib, A., Tabassum, N., 2025. Navigating the labyrinth: A review of explainability and trustworthiness in large language model-powered systems for sensitive decision-making. *Sci. Technol. Sci. Soc.* 2 (7), 5–19. [http://dx.doi.org/10.59324/stss.2025.2\(7\).02](http://dx.doi.org/10.59324/stss.2025.2(7).02), URL: <https://scientia-tss.com/index.php/journal/article/view/100>.
- Astillo, P.V., Duguma, D.G., Park, H., Kim, J., Kim, B., You, I., 2022. Federated intelligence of anomaly detection agent in IoTMD-enabled diabetes management control system. *Future Gener. Comput. Syst.* 128, 395–405. <http://dx.doi.org/10.1016/j.future.2021.10.023>, URL: <https://www.sciencedirect.com/science/article/pii/S0167739X21004192>.
- Avianti, I., Handoyo, S., 2025. A bibliometric analysis of governance, risk, and compliance (GRC): trends, themes, and future directions. *Humanit. Soc. Sci. Commun.* 12 (1), 1945. <http://dx.doi.org/10.1057/s41599-025-06194-9>, URL: <https://www.nature.com/articles/s41599-025-06194-9>.
- Bagaa, M., Taleb, T., Bernabe, J.B., Skarmeta, A., 2020. A machine learning security framework for iot systems. *IEEE Access* 8, 114066–114077. <http://dx.doi.org/10.1109/ACCESS.2020.2996214>, URL: <https://ieeexplore.ieee.org/document/9097876>.
- Bakhshi, T., Ghita, B., Kuzminykh, I., 2024. A review of IoT firmware vulnerabilities and auditing techniques. *Sensors* 24 (2), 708. <http://dx.doi.org/10.3390/s24020708>, URL: <https://www.mdpi.com/1424-8220/24/2/708>.
- Baldini, G., Skarmeta, A., Fournet, E., Neisse, R., Legeard, B., Gall, F.L., 2016. *Security certification and labelling in Internet of Things*.
- Baral, S., Saha, S., Haque, A., 2024. An adaptive end-to-end IoT security framework using explainable AI and LLMs. <http://dx.doi.org/10.48550/arXiv.2409.13177>, URL: <http://arxiv.org/abs/2409.13177>, arXiv:2409.13177 [cs].
- Barati, M., Rana, O., Petri, I., Theodorakopoulos, G., 2020. GDPR compliance verification in Internet of Things. *IEEE Access* 8, 119697–119709. <http://dx.doi.org/10.1109/ACCESS.2020.3005509>.
- Beach, T.H., Hippolyte, J.L., Rezgui, Y., 2020. Towards the adoption of automated regulatory compliance checking in the built environment. *Autom. Constr.* 118, <http://dx.doi.org/10.1016/j.autcon.2020.103285>.
- Bella, G., Castiglione, G., Santamaria, D.F., 2023. An automated method for the ontological representation of security directives. In: *2nd International Workshop KM4LAW*. URL: <http://arxiv.org/abs/2307.01211>.
- Berengueres, J., 2024. How to regulate large language models for responsible AI. *IEEE Trans. Technol. Soc.* 5 (2), 191–197. <http://dx.doi.org/10.1109/TTS.2024.3403681>, URL: <https://ieeexplore.ieee.org/document/10536000>.
- Bicaku, A., Tauber, M., Delsing, J., 2020. Security standard compliance and continuous verification for industrial Internet of Things. *Int. J. Distributed Sens. Netw.* 16, <http://dx.doi.org/10.1177/1550147720922731>.
- Boeckl, K., Fagan, M., Fisher, W., Lefkowitz, N., Megas, K.N., Nadeau, E., O'Rourke, D.G., Piccarreta, B., Scarfone, K., 2019. Considerations for managing Internet of Things (IoT) cybersecurity and privacy risks. <http://dx.doi.org/10.6028/NIST.IR.8228>, URL: <https://nvlpubs.nist.gov/nistpubs/ir/2019/NIST.IR.8228.pdf>.
- Bonnie, E., 2025. Compliance outsourcing: New data measures the ROI of compliance automation and MSSPs. URL: <https://secureframe.com/blog/compliance-outsourcing>.
- Briliyant, O., Javed, A., Cherdantseva, Y., Sunaringtyas, S.U., 2025. Physical tells digital threats: Supervised ML-IDS for multimodal IoT telemetry in smart buildings. In: *2025 IEEE 2nd International Conference on Cryptography, Informatics, and Cybersecurity. ICOCICs*, pp. 204–210. <http://dx.doi.org/10.1109/ICOCICs68032.2025.11384090>, URL: <https://ieeexplore.ieee.org/document/11384090>.
- Burra, M.S., Maity, S., 2022. Certificateless reliable and privacy-preserving auditing of group shared data for FOG-CPSS. *Secur. Commun. Netw.* 2022, <http://dx.doi.org/10.1155/2022/6705948>.
- Cadet, E., Etim, E.D., Essien, I.A., Erigha, E.D., Babatunde, L.A., Ajayi, J.O., Obuse, E., 2024. Large language models for cybersecurity policy compliance and risk mitigation. *Int. J. Sci. Res. Humanit. Soc. Sci.* 1 (2), 612–643. <http://dx.doi.org/10.32628/IJSRSSH242560>, URL: <https://ijsrshs.com/index.php/home/article/view/IJSRSSH242560>.
- Cejas, O.A., Azeem, M.I., Abualhajja, S., Briand, L.C., 2023. NLP-based automated compliance checking of data processing agreements against GDPR. *IEEE Trans. Softw. Eng.* 49, 4282–4303. <http://dx.doi.org/10.1109/TSE.2023.3288901>.
- Cha, S.-C., Meng, W., Li, W.-W., Yeh, K.-H., 2023. A blockchain-enabled IoT auditing management system complying with ISO/IEC 15408-2. *Comput. Ind. Eng.* 178, 109091. <http://dx.doi.org/10.1016/j.cie.2023.109091>, URL: <https://www.sciencedirect.com/science/article/pii/S0360835223001158>.
- Cheng, L., Tian, K., Yao, D.D., Sha, L., Beyah, R.A., 2021. Checking is believing: Event-aware program anomaly detection in cyber-physical systems. *IEEE Trans. Dependable Secur. Comput.* 18, 825–842. <http://dx.doi.org/10.1109/TDSC.2019.2906161>.
- Cheng-Liang Kuo, C.-H.Y., 2015. Security design for configuration management of android device. In: *2015 IEEE 39th Annual Conference on Computer Software and Applications Conference. IEEE*.
- Chu, G., Al-Shareef, F., Wu, H., Hu, Y., Yan, S., 2024. Penetration testing for securing IoT-enabled healthcare systems: A focus on wearable devices and remote surgery. In: *2024 IEEE International Conference on Bioinformatics and Biomedicine. BIBM*, (ISSN: 2156-1133) pp. 5944–5951. <http://dx.doi.org/10.1109/BIBM62325.2024.10822619>, URL: <https://ieeexplore.ieee.org/document/10822619>.

- Chung, N.C., Chung, H., Lee, H., Brocki, L., Chung, H., Dyer, G., 2024. False sense of security in explainable artificial intelligence (XAI). <http://dx.doi.org/10.48550/arXiv.2405.03820>, URL: <http://arxiv.org/abs/2405.03820>, arXiv:2405.03820 [cs]. CICA/AICPA, 1999. Research on continuous auditing.
- Cirne, A., Sousa, P.R., Resende, J.S., Antunes, L., 2022. IoT security certifications: Challenges and potential approaches. *Comput. Secur.* 116, <http://dx.doi.org/10.1016/j.cose.2022.102669>.
- Costin, A., 2015. Large scale security analysis of embedded devices' firmware. URL: <https://www.semanticscholar.org/paper/Large-scale-security-analysis-of-embedded-devices-Costin/f8cf0673986a9d8e2ba2fb24f122b19c8801dc2d>.
- Deldari, S., Goudarzi, M., Joshi, A., Shaghghi, A., Finn, S., Salim, C.D.A.F., Jha, A.S., Salim, F.D., Jha, S., 2024. AuditNet: A conversational AI-based security assistant KEYWORDS. In: MOBILEHCI Adjunct. <http://dx.doi.org/10.1145/3640471.3680444>.
- Deng, G., Liu, Y., Mayoral-Vilches, V., Liu, P., Li, Y., Xu, Y., Zhang, T., Liu, Y., Pinzger, M., Rass, S., 2023. PentestGPT: An LLM-empowered automatic penetration testing tool. URL: <http://arxiv.org/abs/2308.06782>.
- Dong, Z., Tian, M., 2021. Modeling and vulnerability analysis of spatially embedded heterogeneous cyber-physical systems with functional dependency. *IEEE Trans. Netw. Sci. Eng.* 8, 3404–3416. <http://dx.doi.org/10.1109/TNSE.2021.3114332>.
- Dover, T.P., 2021. Evaluating medical IoT (MIoT) device security using NISTIR-8228 expectations. *ArXiv*, URL: [https://www.semanticscholar.org/paper/Evaluating-Medical-IoT\(MIoT\)-Device-Security-using-Dover/9ec28a77f6601941c6795b8505b51353d835544c](https://www.semanticscholar.org/paper/Evaluating-Medical-IoT(MIoT)-Device-Security-using-Dover/9ec28a77f6601941c6795b8505b51353d835544c).
- Dritsas, E., Trigka, M., 2025. A survey on cybersecurity in IoT. *Future Internet* 17 (1), 30. <http://dx.doi.org/10.3390/fi17010030>, URL: <https://www.mdpi.com/1999-5903/17/1/30>.
- Echenim, K.U., Joshi, K.P., 2023. IoT-reg: A comprehensive knowledge graph for real-time IoT data privacy compliance. In: 2023 IEEE International Conference on Big Data. BigData, pp. 2897–2906. <http://dx.doi.org/10.1109/BigData59044.2023.10386545>, URL: <https://ieeexplore.ieee.org/document/10386545>.
- ETSI, 2020. Cyber security for consumer Internet of Things: Baseline requirements. URL: https://www.etsi.org/deliver/etsi_en/303600_303699/303645/02.01.01_60/en_303645v020101p.pdf.
- Fayyazi, R., Taghdimi, R., Yang, S.J., 2024. Advancing TTP analysis: Harnessing the power of large language models with retrieval augmented generation. In: 2024 Annual Computer Security Applications Conference Workshops. ACSAC Workshops, pp. 255–261. <http://dx.doi.org/10.1109/ACSACW65225.2024.00036>, URL: <https://ieeexplore.ieee.org/document/10918057/>.
- Filepp, R., 2018. Continuous Compliance: Experiences, Challenges, and Opportunities. Institute of Electrical and Electronics Engineers Inc., pp. 21–22. <http://dx.doi.org/10.1109/SERVICES.2018.00029>.
- Flores, J.L., Mugarza, I., 2018. Runtime Vulnerability Discovery as a Service on Industrial Internet of Things (IIoT) Systems. Institute of Electrical and Electronics Engineers Inc., pp. 948–955. <http://dx.doi.org/10.1109/ETFA.2018.8502660>.
- Flowerday, S., Blundell, A.W., Solms, R.V., 2006. Continuous auditing technologies and models: A discussion. *Comput. Secur.* 25, 325–331. <http://dx.doi.org/10.1016/j.cose.2006.06.004>.
- Foale, P.L., Silva, L.D., Khomh, F., Li, H., Merlo, E., 2025. Logging requirement for continuous auditing of responsible machine learning-based applications. *Empir. Softw. Eng.* 30 (4), 97. <http://dx.doi.org/10.1007/s10664-025-10656-8>.
- for Digital Culture Media & Sport, U.G.D., 2018. Code of practice for consumer IoT security. URL: <https://www.gov.uk/government/publications/secure-by-design>.
- for Network, E.U.A., Security, I., 2017. Baseline security recommendations for IoT in the context of critical information infrastructures. URL: <https://www.enisa.europa.eu/publications/baseline-security-recommendations-for-iiot>.
- Friha, O., Amine Ferrag, M., Kantarci, B., Cakmak, B., Ozgun, A., Ghoulalmi-Zine, N., 2024. LLM-based edge intelligence: A comprehensive survey on architectures, applications, security and trustworthiness. *IEEE Open J. Commun. Soc.* 5, 5799–5856. <http://dx.doi.org/10.1109/OJCOMS.2024.3456549>, URL: <https://ieeexplore.ieee.org/document/10669603>.
- Galis, M., 2023. How leveraging AI can revolutionize security compliance audits. URL: <https://www.forbes.com/councils/forbestechcouncil/2023/12/20/how-leveraging-ai-can-revolutionize-security-compliance-audits/>.
- Ghanem, M.C., Chen, T.M., Ferrag, M.A., Kettouche, M.E., 2023. ESASCF: Expertise extraction, generalization and reply framework for optimized automation of network security compliance. *IEEE Access* 11, 129840–129853. <http://dx.doi.org/10.1109/ACCESS.2023.3332834>.
- Ghosh, R., Farri, O., Stockhausen, H.-M.v., Schmitt, M., Vasile, G.M., 2024. CVE-LLM : Automatic vulnerability evaluation in medical device industry using large language models. <http://dx.doi.org/10.48550/arXiv.2407.14640>, URL: <http://arxiv.org/abs/2407.14640>, arXiv:2407.14640 [cs].
- Gokhan, T., Wang, K., Gurevych, I., Briscoe, T., 2024. RegNLP in action: Facilitating compliance through automated information retrieval and answer generation. URL: <http://arxiv.org/abs/2409.05677>.
- Hahn, A., Govindarasu, M., 2011. An evaluation of cybersecurity assessment tools on a SCADA environment. <http://dx.doi.org/10.1109/PES.2011.6039845>.
- Hamdani, R.E., Mustapha, M., Amariles, D.R., Troussel, A., Meelis, S., Krasnashchok, K., 2021. A Combined Rule-Based and Machine Learning Approach for Automated GDPR Compliance Checking. Association for Computing Machinery, Inc, pp. 40–49. <http://dx.doi.org/10.1145/3462757.3466081>.
- Hanson, D., Straub, J., 2024. A systematic review of cybersecurity audit frameworks for the Internet of Things. In: 2024 IEEE International Conference on Cyber Security and Resilience. CSR, pp. 133–138. <http://dx.doi.org/10.1109/CSR61664.2024.10679377>, URL: <https://ieeexplore.ieee.org/document/10679377/>.
- Hashmat, F., Abbas, S.G., Hina, S., Shah, G.A., Bakhshi, T., Abbas, W., 2022. An automated context-aware IoT vulnerability assessment rule-set generator. *Comput. Commun.* 186, 133–152. <http://dx.doi.org/10.1016/j.comcom.2022.01.022>.
- Hassani, H.L., Bahnasse, A., Martin, E., Roland, C., Bouattane, O., Mehdi Diouri, M.E., 2021. Vulnerability and security risk assessment in an IIoT environment in compliance with standard IEC 62443. *Procedia Comput. Sci.* 191, 33–40. <http://dx.doi.org/10.1016/j.procs.2021.07.008>, URL: <https://www.sciencedirect.com/science/article/pii/S1877050921014009>.
- Hildebrandt, C., Woodlief, T., Elbaum, S., 2024. ODD-dillMma: Driving automation system ODD compliance checking using LLMs. In: 2024 IEEE/RSJ International Conference on Intelligent Robots and Systems. IROS, pp. 13809–13816. <http://dx.doi.org/10.1109/IROS58592.2024.10801369>, URL: <https://ieeexplore.ieee.org/document/10801369/>.
- Hillo, R.V., Weigand, H., 2016. Continuous Auditing & Continuous Monitoring: Continuous Value? IEEE Computer Society, <http://dx.doi.org/10.1109/RCIS.2016.7549279>.
- Hosseini, A.M., Kastner, W., Sauter, T., 2025. Leveraging LLMs and knowledge graphs to design secure automation systems. *IEEE Open J. Ind. Electron. Soc.* 6, 380–395. <http://dx.doi.org/10.1109/OJIES.2025.3545811>, URL: <https://ieeexplore.ieee.org/document/10904297/>.
- IIA, 2025. GTAG: Continuous Auditing and Monitoring, third ed. Institute of Internal Auditors, URL: <https://www.theiia.org/en/content/guidance/recommended-supplemental/gtags/continuous-auditing-and-monitoring/>.
- Iqbal, A., Zia, U., Aman, M.N., Sikdar, B., 2024. RAM-based firmware attestation for IoT security: A representation learning framework. *IEEE Internet Things J.* 11 (21), 35124–35140. <http://dx.doi.org/10.1109/JIOT.2024.3436057>, URL: <https://ieeexplore.ieee.org/document/10616208>.
- ISACA, 2019. Certified Information System Auditor Review Manual, twentyseventh ed. ISACA.
- Islam, C., Babar, M.A., Croft, R., Janicke, H., 2022. SmartValidator: A framework for automatic identification and classification of cyber threat data. *J. Netw. Comput. Appl.* 202, <http://dx.doi.org/10.1016/j.jnca.2022.103370>.
- Ito, K., Morisaki, S., Goto, A., 2021. IoT security-quality-metrics method and its conformity with emerging guidelines. *IoT J.* 2 (4), 761–785. <http://dx.doi.org/10.3390/iot2040038>, URL: <https://www.mdpi.com/2624-831X/2/4/38>, Number: 4 Publisher: Multidisciplinary Digital Publishing Institute.
- Jaigirdar, F.T., Rudolph, C., Bain, C., 2021. Risk and compliance in IIoT: Health data propagation: A security-aware provenance based approach. In: 2021 IEEE International Conference on Digital Health. ICDH, pp. 27–37. <http://dx.doi.org/10.1109/ICDH52753.2021.00015>, URL: <https://ieeexplore.ieee.org/document/9581214>.
- Jans, M., Hosseinpour, M., 2019. How active learning and process mining can act as continuous auditing catalyst. *Int. J. Account. Inf. Syst.* 32, 44–58. <http://dx.doi.org/10.1016/j.accinf.2018.11.002>.
- Jin, J., Tang, B., Ma, M., Liu, X., Wang, Y., Lai, Q., Yang, J., Zhou, C., 2024. Crimson: Empowering strategic reasoning in cybersecurity through large language models. In: 2024 5th International Conference on Computer, Big Data and Artificial Intelligence. ICCBD+AI, pp. 18–24. <http://dx.doi.org/10.1109/ICCBDAI65562.2024.00011>, URL: <https://ieeexplore.ieee.org/document/10933698>.
- Ju, H., 2024. Reliable online log parsing using large language models with retrieval-augmented generation. In: 2024 IEEE 35th International Symposium on Software Reliability Engineering Workshops. ISSREW, IEEE, Tsukuba, Japan, pp. 99–102. <http://dx.doi.org/10.1109/ISSREW63542.2024.00055>, URL: <https://ieeexplore.ieee.org/document/10771378/>.
- Jüttner, V., Grimmer, M., Buchmann, E., 2023. ChatIDS: Explainable cybersecurity using generative AI. URL: <http://arxiv.org/abs/2306.14504>.
- Kagita, M.K., Bojja, G.R., Kaosar, M., 2021. A framework for intelligent IoT firmware compliance testing. *Internet Things Cyber-Phys. Syst.* 1, 1–7. <http://dx.doi.org/10.1016/j.iotcps.2021.07.001>.
- Kahneman, D., Tversky, A., 1979. Prospect theory: An analysis of decision under risk. *Econometrica* 47 (2), 263–291. <http://dx.doi.org/10.2307/1914185>, URL: <https://www.jstor.org/stable/1914185>.
- Kaksonen, R., Halunen, K., Laakso, M., Rönning, J., 2025. Automating IoT security standard testing by common security tools. pp. 42–53, URL: <https://www.scitepress.org/Link.aspx?doi=10.5220/0012345900003648>.
- Kellogg, M., Schaf, M., Tasiran, S., Ernst, M.D., 2020. Continuous Compliance. Institute of Electrical and Electronics Engineers Inc., pp. 511–523. <http://dx.doi.org/10.1145/3324884.3416593>.
- Kholgh, D.K., Kostakos, P., 2023. PAC-GPT: A novel approach to generating synthetic network traffic with GPT-3. *IEEE Access* 11, 114936–114951. <http://dx.doi.org/10.1109/access.2023.3325727>, URL: <https://ieeexplore.ieee.org/document/10287342/>, Publisher: Institute of Electrical and Electronics Engineers (IEEE).
- Khurshid, A., Raza, S., 2023. AutoCert: Automated TOCTOU-secure digital certification for IoT with combined authentication and assurance. *Comput. Secur.* 124, 102952. <http://dx.doi.org/10.1016/j.cose.2022.102952>, URL: <https://www.sciencedirect.com/science/article/pii/S0167404822003443>.

- Kohli, V., Aman, M.N., Sikdar, B., 2024. SAFE-IoT: Attesting firmware in IoT swarms using volatile memory and a mixture of experts. In: 2024 IEEE Conference on Communications and Network Security. CNS, (ISSN: 2994-5895) pp. 1–9. <http://dx.doi.org/10.1109/CNS62487.2024.10735468>, URL: <https://ieeexplore.ieee.org/document/10735468>.
- Konstantinidis, K., 2017. Automated cyber security compliance assessment evaluating cyber security standards through an architectural modeling prism.
- Koschorreck, G., 2011. Automated audit of compliance and security controls. pp. 137–148. <http://dx.doi.org/10.1109/IMF.2011.12>.
- Kotak, J., Elovici, Y., 2023. IoT device identification based on network communication analysis using deep learning. *J. Ambient Intell. Humaniz. Comput.* 14 (7), 9113–9129. <http://dx.doi.org/10.1007/s12652-022-04415-6>, URL: <http://arxiv.org/abs/2303.12800>, arXiv:2303.12800 [cs].
- KPMG, 2023. 2023 chief ethics and compliance officer survey. URL: <https://kpmg.com/us/en/media/news/cco-2023-survey.html>.
- KPMG, 2024. Stepping up to a new level of compliance. In: 2024 CCOs Global Survey. KPMG.
- Kulik, T., Tran-Jorgensen, P., Boudjadar, J., 2020. Compliance verification of a cyber security standard for cloud-connected SCADA.
- Kumar, A., Kavisankar, L., Venkatesan, S., Kumar, M., Yadav, S., Shukla, S.K., Khondoker, R., 2024. IoT device security audit tools: a comprehensive analysis and a layered architecture approach for addressing expanded security requirements. *Int. J. Inf. Secur.* 24 (1), 13. <http://dx.doi.org/10.1007/s10207-024-00930-z>.
- Kumar, R., Kumar, P., Aloqaily, M., Aljuhani, A., 2023. Deep-learning-based blockchain for secure zero touch networks. *IEEE Commun. Mag.* 61 (2), 96–102. <http://dx.doi.org/10.1109/MCOM.001.2200294>, URL: <https://ieeexplore.ieee.org/document/9982300/>.
- Kurniawan, K., Kiesling, E., Ekelhart, A., 2022. CyKG-RAG: Towards knowledge-graph enhanced retrieval augmented generation for cybersecurity.
- Lins, S., Schneider, S., Sunyaev, A., 2018. Trust is good, control is better: Creating secure clouds by continuous auditing. *IEEE Trans. Cloud Comput.* 6, 890–903. <http://dx.doi.org/10.1109/TCC.2016.2522411>.
- Lorenz, C., Clemens, V., Schrotter, M., Schnor, B., 2022. Continuous verification of network security compliance. *IEEE Trans. Serv. Manag.* 19, 1729–1745. <http://dx.doi.org/10.1109/TNSM.2021.3130290>.
- Lubell, J., Zimmerman, T., 2017. Challenges to Automating Security Configuration Checklists in Manufacturing Environments. Springer New York LLC, pp. 225–241. http://dx.doi.org/10.1007/978-3-319-70395-4_12.
- MacAk, M., Vanat, I., Merjavay, M., Jevocin, T., Buhnova, B., 2020. Towards Process Mining Utilization in Insider Threat Detection from Audit Logs. Institute of Electrical and Electronics Engineers Inc., <http://dx.doi.org/10.1109/SNAMS52053.2020.9336573>.
- Majumdar, S., 2020. A multi-level proactive security auditing framework for clouds through automated dependency building. *CCF Trans. Netw.* 3, 112–127. <http://dx.doi.org/10.1007/s42045-020-00028-9>.
- Majumdar, S., Bastos, D., Singhal, A., 2021. Security auditing of internet of things devices in a smart home.
- Markina, M.S., Markin, P.V., Voevodin, V.A., Burenok, D.S., 2021. Methodology for Quantifying the Materiality of Audit Evidence Using Expert Assessments and Their Ranking. Institute of Electrical and Electronics Engineers Inc., pp. 2390–2393. <http://dx.doi.org/10.1109/ElConRus51938.2021.9396263>.
- Matheu, S.N., Hernández-Ramos, J.L., Skarmeta, A.F., Baldini, G., 2021. A survey of cyber-security certification for the Internet of Things. <http://dx.doi.org/10.1145/3410160>.
- Matheu-García, S.N., Hernández-Ramos, J.L., Skarmeta, A.F., Baldini, G., 2019. Risk-based automated assessment and testing for the cybersecurity certification and labelling of IoT devices. *Comput. Stand. Interfaces* 62, 64–83. <http://dx.doi.org/10.1016/j.csi.2018.08.003>, URL: <https://www.sciencedirect.com/science/article/pii/S0920548918301375>.
- Matsumoto, N., Fujita, J., Endoh, H., Yamada, T., Sawada, K., Kaneko, O., 2021. Asset management method of industrial iot systems for cyber-security countermeasures. *Inf. (Switz.)* 12, <http://dx.doi.org/10.3390/info12110460>.
- Mohsin, M., Anwar, Z., Husari, G., Al-Shaer, E., Rahman, M.A., 2016. IoTSAT: A formal framework for security analysis of the internet of things (IoT). In: 2016 IEEE Conference on Communications and Network Security. CNS, pp. 180–188. <http://dx.doi.org/10.1109/CNS.2016.7860484>, URL: <https://ieeexplore.ieee.org/document/7860484/>.
- Mohsin, M., Anwar, Z., Zaman, F., Al-Shaer, E., 2017. IoTChecker: A data-driven framework for security analytics of internet of things configurations. *Comput. Secur.* 70, 199–223. <http://dx.doi.org/10.1016/j.cose.2017.05.012>.
- Murikah, W., Nthenge, J.K., Musyoka, F.M., 2024. Bias and ethics of AI systems applied in auditing - A systematic review. *Sci. Afr.* 25, e02281. <http://dx.doi.org/10.1016/j.sciaf.2024.e02281>, URL: <https://www.sciencedirect.com/science/article/pii/S2468227262400266>.
- Nadir, I., Ahmad, Z., Mahmood, H., Asadullah Shah, G., Shahzad, F., Umair, M., Khan, H., Gulzar, U., 2019. An auditing framework for vulnerability analysis of IoT system. In: 2019 IEEE European Symposium on Security and Privacy Workshops. EuroS&PW, pp. 39–47. <http://dx.doi.org/10.1109/EuroSPW.2019.00011>, URL: <https://ieeexplore.ieee.org/document/8802414/>.
- NIST, 2020. Security and privacy controls for information systems and organizations. <http://dx.doi.org/10.6028/NIST.SP.800-53r5>, URL: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>.
- Oranekwu, I., Elluri, L., Batra, G., 2024. Automated knowledge framework for IoT cybersecurity compliance. In: 2024 IEEE International Conference on Big Data. Big-Data, (ISSN: 2573-2978) pp. 6336–6345. <http://dx.doi.org/10.1109/BigData62323.2024.10825755>, URL: <https://ieeexplore.ieee.org/document/10825755>.
- OWASP, 2018. OWASP Internet of Things project - OWASP. URL: https://wiki.owasp.org/index.php/OWASP_Internet_of_Things_Project#tab=IoT_Top_10.
- OWASP, Guzman, A., Bassem, C., 2021. OWASP IoT security verification standard. URL: <https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS>.
- Paduraru, C., Patilea, C., Stefanescu, A., 2025. CyberGuardian 2: Integrating LLMs and agentic AI assistants for securing distributed networks. pp. 660–667, URL: <https://www.scitepress.org/Link.aspx?doi=10.5220/0013406000003928>.
- Page, M.J., McKenzie, J.E., Bossuyt, P.M., Boutron, I., Hoffmann, T.C., Mulrow, C.D., Shamseer, L., Tetzlaff, J.M., Akl, E.A., Brennan, S.E., Chou, R., Glanville, J., Grimshaw, J.M., Hróbjartsson, A., Lalu, M.M., Li, T., Loder, E.W., Mayo-Wilson, E., McDonald, S., McGuinness, L.A., Stewart, L.A., Thomas, J., Tricco, A.C., Welch, V.A., Whiting, P., Moher, D., 2021. The PRISMA 2020 statement: an updated guideline for reporting systematic reviews. *BMJ* 372, <http://dx.doi.org/10.1136/bmj.n71>, arXiv:https://www.bmj.com/content/372/bmj.n71.full.pdf, URL: <https://www.bmj.com/content/372/bmj.n71>.
- Pal, S., Tan, W.-H., Foo, Y.-L., 2023. Privacy-focused edge AI-on-IoT with federated learning. In: 2023 IEEE 8th International Conference on Recent Advances and Innovations in Engineering. ICRAlE, pp. 1–6. <http://dx.doi.org/10.1109/ICRAIE59459.2023.10468159>, URL: <https://ieeexplore.ieee.org/document/10468159>.
- Peterside, G.B., Zavarsky, P., Butakov, S., 2016. Automated Security Configuration Checklist for a Cisco Ispsec vpn Router Using SCAP 1.2. Institute of Electrical and Electronics Engineers Inc., pp. 355–360. <http://dx.doi.org/10.1109/ICITST.2015.7412120>.
- Philippaerts, P., Preuveneers, D., Joosen, W., 2022. OAuch: Exploring Security Compliance in the OAuth 2.0 Ecosystem. Association for Computing Machinery, pp. 460–481. <http://dx.doi.org/10.1145/3545948.3545955>.
- Pozdniakov, K., Alonso, E., Stankovic, V., Alonso, E., Uk, A., Tam, K., Jones, K., 2020. Smart security audit: Reinforcement learning with a deep neural network approximator; smart security audit: Reinforcement learning with a deep neural network approximator.
- PricewaterhouseCoopers, 2025. Global compliance survey 2025. URL: <https://www.pwc.com/gx/en/issues/risk-regulation/global-compliance-survey.html>.
- Rizvi, S., Campbell, S., Alden, K., 2020. Why Compliance is needed for Internet of Things? Institute of Electrical and Electronics Engineers Inc., pp. 66–71. <http://dx.doi.org/10.1109/ICSSA51305.2020.00019>.
- Rizvi, S., Zwerling, T., Thompson, B., Faiola, S., Campbell, S., Fisanick, S., Hutnick, C., 2023. A modular framework for auditing IoT devices and networks. *Comput. Secur.* 132, 103327. <http://dx.doi.org/10.1016/j.cose.2023.103327>, URL: <https://linkinghub.elsevier.com/retrieve/pii/S0167404823002377>.
- Sabillon, R., Serra-Ruiz, J., Cavaller, V., Cano, J., 2018. A Comprehensive Cybersecurity Audit Model to Improve Cybersecurity Assurance: The Cybersecurity Audit Model (CSAM). Institute of Electrical and Electronics Engineers Inc., pp. 253–259. <http://dx.doi.org/10.1109/INCISCOS.2017.20>.
- Salva, S., Blot, E., 2021. MLCA: A model-learning-checking approach for IoT systems. In: van Sinderen, M., Maciaszek, L.A., Fill, H.-G. (Eds.), *Software Technologies*. Springer International Publishing, Cham, pp. 70–97. http://dx.doi.org/10.1007/978-3-030-83007-6_4.
- Salva, S., Blot, E., 2025. Verifying the application of security measures in IoT software systems with model learning. pp. 350–360, URL: <https://www.scitepress.org/Link.aspx?doi=10.5220/0009872103500360>.
- Scarfone, K., Souppaya, M., Cody, A., Orebaugh, A., 2021. Special publication 800-115 technical guide to information security testing and assessment recommendations of the national institute of standards and technology.
- Seul, M., Varol, C., 2023. Leveraging P2P- and edge-based processing for compliance management of IoT-devices. In: 2023 11th International Symposium on Digital Forensics and Security. ISDFS, pp. 1–7. <http://dx.doi.org/10.1109/ISDFS58141.2023.10131121>, URL: <https://ieeexplore.ieee.org/document/10131121>.
- Sicari, S., Rizzardi, A., Miorandi, D., Coen-Porisini, A., 2018. A risk assessment methodology for the Internet of Things. *Comput. Commun.* 129, 67–79. <http://dx.doi.org/10.1016/j.comcom.2018.07.024>.
- Sivakumaran, P., Blasco, J., 2021. argXtract: Deriving IoT security configurations via automated static analysis of stripped ARM binaries. ArXiv URL: <https://www.semanticscholar.org/paper/argXtract%3A-Deriving-IoT-Security-Configurations-via-Sivakumaran-Blasco/a9fc11e1c6cde4dfd59d454bf22946b7737dd07>.
- Sivanathan, A., 2020. IoT behavioral monitoring via network traffic analysis. <http://dx.doi.org/10.48550/arXiv.2001.10632>, URL: <http://arxiv.org/abs/2001.10632>, arXiv:2001.10632 [cs].
- Slapničar, S., Vuko, T., Čular, M., Drašček, M., 2022. Effectiveness of cybersecurity audit. *Int. J. Account. Inf. Syst.* 44, <http://dx.doi.org/10.1016/j.accinf.2021.100548>.

- Srivastava, P., Peng, H., Li, J., Okhravi, H., Shrobe, H., Payer, M., 2019. FirmFuzz: Automated IoT firmware introspection and analysis. In: Proceedings of the 2nd International ACM Workshop on Security and Privacy for the Internet-of-Things. In: IoT S&P'19, Association for Computing Machinery, New York, NY, USA, pp. 15–21. <https://dx.doi.org/10.1145/3338507.3358616>, URL: <https://dl.acm.org/doi/10.1145/3338507.3358616>.
- Sun, P., Wan, Y., Wu, Z., Fang, Z., Li, Q., 2025. A survey on privacy and security issues in IoT-based environments: Technologies, protection measures and future directions. *Comput. Secur.* 148, 104097. <https://dx.doi.org/10.1016/j.cose.2024.104097>, URL: <https://www.sciencedirect.com/science/article/pii/S0167404824004024>.
- Tauqeer, A., Kurteva, A., Chhetri, T.R., Ahmeti, A., Fensel, A., 2022. Automated GDPR contract compliance verification using knowledge graphs. *Inf. (Switz.)* 13, <https://dx.doi.org/10.3390/info13100447>.
- Thakur, V., 2025. Fintech micro SaaS compliance: 12 countries cost analysis [2025 data]. URL: <https://www.rockingweb.com.au/fintech-micro-saas-regulatory-nightmare-compliance>.
- Tihanyi, N., Ferrag, M.A., Jain, R., Bisztray, T., Debbah, M., 2024. CyberMetric: A benchmark dataset based on retrieval-augmented generation for evaluating LLMs in cybersecurity knowledge. <https://dx.doi.org/10.1109/CSR61664.2024.10679494>, URL: <https://arxiv.org/abs/2402.07688>.
- Turner, R.C., 2022. Process Mining for Asymmetric Cybersecurity Audit. Institute of Electrical and Electronics Engineers Inc., pp. 293–298. <https://dx.doi.org/10.1109/CSR54599.2022.9850298>.
- Upadhyaya, S.K., Thangaraju, B., 2022. A novel method for trusted audit and compliance for network devices by using blockchain. In: 2022 IEEE International Conference on Electronics, Computing and Communication Technologies, CONECCT 2022. Institute of Electrical and Electronics Engineers Inc., <https://dx.doi.org/10.1109/CONECCT55679.2022.9865836>.
- Varela-Vaca, Á.J., Gasca, R.M., Ceballos, R., Gómez-López, M.T., Torres, P.B., 2019. Cyberspl: a framework for the verification of cybersecurity policy compliance of system configurations using software product lines. p. 9(24):5364.
- Vasarhelyi, M.A., 1991. The continuous audit of online systems audit 4.0 view project applications of data analytics: Visualization and cluster analysis of governmental data view project. URL: <https://www.researchgate.net/publication/255667612>.
- Vutukuru, e.a.S.R., 2023. SecureIoT: Novel machine learning algorithms for detecting and preventing attacks on IoT devices. *J. Electr. Syst.* 19 (4), 315–335. <https://dx.doi.org/10.52783/jes.641>, URL: <https://journal.esrgroups.org/jes/article/view/641>, Number: 4.
- Waltermire, D., Fitzgerald-McKay, J., 2018. Transitioning to the security content automation protocol (SCAP) version 2. <https://dx.doi.org/10.6028/NIST.CSWP.09102018>, URL: <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.09102018.pdf>.
- Wang, Q., Ji, S., Tian, Y., Zhang, X., Zhao, B., Kan, Y., Lin, Z., Lin, C., Deng, S., Liu, A.X., Beyah, R., 2022. MPInspector: A systematic and automatic approach for evaluating the security of IoT messaging protocols. <https://dx.doi.org/10.48550/arXiv.2208.08751>, URL: <https://arxiv.org/abs/2208.08751>, arXiv:2208.08751 [cs].
- Wang, T., Mei, Y., Liu, X., Wang, J., Dai, H.N., Wang, Z., 2021. Edge-based auditing method for data security in resource-constrained Internet of Things. *J. Syst. Archit.* 114, <https://dx.doi.org/10.1016/j.sysarc.2020.101971>.
- Xia, B., Lu, Q., Zhu, L., Lee, S.U., Liu, Y., Xing, Z., 2024. Towards a responsible AI metrics catalogue: A collection of metrics for AI accountability. In: Proceedings of the IEEE/ACM 3rd International Conference on AI Engineering - Software Engineering for AI. CAIN '24, Association for Computing Machinery, New York, NY, USA, pp. 100–111. <https://dx.doi.org/10.1145/3644815.3644959>, URL: <https://dl.acm.org/doi/10.1145/3644815.3644959>.
- Yu, B., Zhang, Y., Zhang, Y., Yang, Q., 2023. Firm VEA: Vulnerability discovery optimisation for IoT firmware via version evolution analysis. In: GLOBECOM 2023 - 2023 IEEE Global Communications Conference. (ISSN: 2576-6813) pp. 5019–5024. <https://dx.doi.org/10.1109/GLOBECOM54140.2023.10437669>, URL: <https://ieeexplore.ieee.org/document/10437669>.
- Zhang, J., El-Gohary, N., 2012. Automated regulatory information extraction from building codes leveraging syntactic and semantic information.
- Zhang, J., El-Gohary, N.M., 2016. Semantic-based logic representation and reasoning for automated regulatory compliance checking. [https://dx.doi.org/10.1061/\(ASCE\).cp.1943-5487.0001014](https://dx.doi.org/10.1061/(ASCE).cp.1943-5487.0001014).
- Zhang, R., El-Gohary, N., 2022. Hierarchical representation and deep learning-based method for automatically transforming textual building codes into semantic computable requirements. *J. Comput. Civ. Eng.* 36, [https://dx.doi.org/10.1061/\(asce\).cp.1943-5487.0001014](https://dx.doi.org/10.1061/(asce).cp.1943-5487.0001014).
- Zhang, Y., Yang, J., Lei, H., Bao, Z., Lu, N., Shi, W., Chen, B., 2024. PACTA: An IoT data privacy regulation compliance scheme using TEE and blockchain. *IEEE Internet Things J.* 11 (5), 8882–8893. <https://dx.doi.org/10.1109/JIOT.2023.3321308>, URL: <https://ieeexplore.ieee.org/document/10268608/>.
- Zheng, Z., Zhou, Y.C., Lu, X.Z., Lin, J.R., 2022. Knowledge-informed semantic alignment and rule interpretation for automated compliance checking. *Autom. Constr.* 142, <https://dx.doi.org/10.1016/j.autcon.2022.104524>.



Obrina Briliyant is currently active as a full-time research student in the [School of Computer Science and Informatics, Cardiff University](#). Previously, he was a research associate and an experienced IT auditor in Indonesia, with focus on IT/IS security assessment and audit based on COBIT, ISO 27001, CIS, and OWASP. He is still active in the Indonesian Cyber Security Agency (BSSN) and ISACA Indonesia Chapter. His main interests are automated cyber defense and privacy-preserving systems for IoT environment.



Dr. Amir Javed is a cybersecurity professional and academic. He serves as Senior Lecturer at [Cardiff University](#), leading research in cybercriminal behaviour analysis, cyber risk, and AI in security. He holds a PhD in Cybersecurity and an MSc in Information Security and Privacy, and is CISSP certified. His work includes collaborations with GCHQ, Airbus, Thales, and The Alan Turing Institute. He is also a Domain Knowledge Expert at the Wales Cyber Innovation Hub and mentor at T-Hub. With over 16 years' experience, he advances cybersecurity through research, innovation, and industry engagement and supports startups in building scalable solutions.



Dr. Yulia Cherdantseva is a Reader in the [School of Computer Science and Informatics, Cardiff University](#) and serves as Director of Cardiff University's Academic Centre of Excellence in Cyber Security Education (ACE-CSE). Her research interests include the design of secure information systems; SCADA/ICS cybersecurity; cybersecurity for small and medium-sized enterprises (SMEs); cybersecurity education pedagogy; and cybersecurity workforce development.